



Digital Forensics and Cybersecurity

ADVANCED FORENSICS

ACTIVE DIRECTORY POST-INVESTIGATION

by: Abdullah Zia

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY	1
2. INTRODUCTION AND METHODOLOGY	1
2.1. Objective & Scope	1
2.2. Forensic Methodology	2
2.2.1. Volatile Data Acquisition (Live Response)	2
2.2.2. Dead Disk Acquisition	2
2.2.3. Analysis & Correlation.....	3
2.3. Chain of Custody & Integrity Verification (Cryptographic Hashes).....	3
2.4. Forensic Toolset & Technical Specifications	4
2.5. Evidence Acquisition & Inventory	5
2.6. Advanced Forensic Methodology: NTDS.dit Decryption	6
2.7. Advanced Artifact Analysis	7
2.8. Credential Analysis & Password Cracking Results	14
3. INCIDENT RECONSTRUCTION AND FORENSIC ANALYSIS.....	14
3.1 Baseline Activity Analysis	15
3.2 Initial Access	21
3.3 Lateral Movement	24
3.4 Persistence (Backdoors & Privilege Escalation)	26
3.5 Domain Dominance (DCShadow Attack).....	33
3.6 Action on Objectives (Data Exfiltration)	39
4. LEGAL PERSPECTIVE FOR EVIDENCE HANDLING	40
4.1 Evidence Acquisition Under PECA	40
4.1.1. Legal Requirements for Collecting Digital Evidence	40
4.1.2. Permission & Authorization	41
4.1.3. Role of FIA Cyber Crime Wing.....	41

4.2. Evidence Retention Policy	41
4.2.1. Data Preservation Orders	41
4.2.2. Penalties for Tampering	42
4.3. Legal Considerations (PECA Violations)	42
4.4. Ethical Considerations	42
4.4.1. Privacy of User Data	42
4.4.2. Confidentiality of Sensitive Artifacts.....	43
5. RECOMMENDATION FOR REMEDIATION & MITIGATION	43
5.1. Immediate Containment (Kill Switch)	43
5.2. Eradication & System Hardening	43
5.3. Strategic Policy Improvements	44
6.CONCLUSION	44
6.1. Investigation Summary	44
6.2. Final Verdict.....	45

1. Executive Summary

This report details the forensic investigation into a Advanced Persistent Threat (APT) attack targeting the corporate domain CORP.LOCAL. The investigation was conducted to reconstruct the attack lifecycle, identify the extent of the compromise, and secure forensic evidence for legal proceedings under the Prevention of Electronic Crimes Act (PECA) 2016.

The investigation successfully confirmed a full domain compromise. The attacker, operating from the IP address **192.168.50.5**, executed a sophisticated multi-stage attack:

- 1. Initial Access:** A high-volume brute-force attack successfully compromised the Administrator account.
- 2. Lateral Movement:** The attacker utilized the Impacket toolset to move laterally to the Domain Controller (DC01) via SMB named pipes (IPC\$).
- 3. Persistence:** Long-term access was established through a Sticky Keys backdoor in the Registry and the creation of a rogue service account (svc_azure_sync).
- 4. Domain Dominance (DCShadow):** The attacker registered a rogue computer (WIN-DR-REP01\$) to mimic a Domain Controller, a precursor to a DCShadow attack aimed at modifying the Active Directory schema.
- 5. Data Exfiltration:** Sensitive financial audit data (Q4_2025_Audit.accdb) was stolen from the restricted Finance_Backups share.

All findings are supported by digital artifacts recovered from Security Event Logs, System Logs, Registry Hives, and the NTDS.dit database.

2. Introduction & Methodology

2.1. Objective & Scope

The primary objective of this investigation was to conduct a comprehensive Digital Forensic Post-Incident Analysis (DF-PIA) of a compromised Domain Controller within the CORP.LOCAL environment. The investigation aimed to reconstruct the complete "Cyber Kill Chain" of an Advanced Persistent Threat (APT) actor, identifying the initial vector of compromise, the mechanism of lateral movement, and the extent of data exfiltration.

The scope of this forensic audit was expanded beyond standard log analysis to include a Hybrid Forensic Approach, combining volatile data analysis with offline "Dead Disk" forensics. The specific objectives included:

- **Identity Forensics:** Analyzing authentication logs to trace the brute-force trajectory and identify compromised user accounts.
- **Persistence Analysis:** Examining the Windows Registry and Active Directory database (NTDS) for stealthy backdoors, including "Sticky Keys" and rogue object injection.
- **Infrastructure Integrity Check:** Verifying the integrity of the Active Directory Schema and Replication topology to detect sophisticated "DCShadow" attacks.
- **Data Exfiltration Analysis:** Correlating network share access logs with file system timestamps to confirm the theft of sensitive financial artifacts.

2.2. Forensic Methodology

To ensure the admissibility of evidence under the Prevention of Electronic Crimes Act (PECA) 2016, the investigation adhered to a strict, four-phase forensic workflow. This structured approach ensures that all artifacts are preserved, authenticated, and analyzed without altering the state of the original evidence.

2.2.1. Volatile Data Acquisition

The first phase focused on capturing "fragile" evidence from the running system before it could be overwritten or lost due to a reboot.

- **Log Preservation:** The Windows Event Log service was queried to export the Security, System, and PowerShell Operational logs into strict .evtx format.
- **Registry Hives:** The current state of all the Registry hives was exported to verify active persistence mechanisms.

2.2.2. Dead Disk Acquisition

To bypass the file locks imposed by the operating system on critical system files, a "Dead Disk" acquisition strategy was employed.

- **Volume Shadow Copy (VSS):** A Volume Shadow Copy was created on the Domain Controller. This allowed the forensic team to copy the locked ntds.dit (Active Directory Database) and the SYSTEM registry hive (containing the Boot Key) without disrupting network services.
- **Secure Extraction:** These artifacts were moved to a secure, air-gapped forensic workstation for offline decryption and analysis.

```

C:\Users\Administrator>vssadmin create shadow /for=C:
vssadmin 1.1 - Volume Shadow Copy Service administrative command-line tool
(C) Copyright 2001-2013 Microsoft Corp.

Successfully created shadow copy for 'C:\'
Shadow Copy ID: {e20a395f-eae7-475b-be66-1991ea54628b}
Shadow Copy Volume Name: \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy4

```

Figure 1: Execution of vssadmin command to create Volume Shadow Copy of C drive

2.2.3. Analysis & Correlation

The analysis phase utilized a "Time-Lining" technique to correlate disparate data points into a cohesive attack narrative.

- **Event Correlation:** Timestamps from the Security Logs (e.g., login times) were cross-referenced with File System metadata (e.g., file creation times) to distinguish between legitimate user activity and attacker actions.
- **Database Parsing:** The decrypted NTDS database was parsed to recover hidden object attributes such as the AdminCount flag and rogue ServicePrincipalNames that are not visible in the standard Windows Event Viewer.

2.3. Chain of Custody & Integrity Verification (Cryptographic Hashes)

To ensure the integrity of the collected digital evidence and to comply with PECA 2016 Section 30 (Admissibility), a cryptographic hash was generated for every artifact immediately upon acquisition. These hashes serve as a digital fingerprint; any future modification to these files will result in a different hash value, indicating tampering.

Algorithm	Hash	File Name
SHA256	670EE43389007A123089DC65759003C53090B8A12A8D221B18 CBCAB2A07ADECBC	Security.evtx
SHA256	81C083FF7CA36EC50A5280BD1E52FD37F4A8029261342A412A 97DD526354DACD	System.evtx
SHA256	1B1C6FDDD7B4EFCDA826F8248E31D4484B54C76640FD9F4C 28D37FCEBD53A45C	ntds.dit
SHA256	7C2DB94B44D09E140F4D0A48E3E0DF23E4D563496B10D34A2 0AFC407F47F867B	SAM
SHA256	83B57BB18BE8C5449C0A76CB0F768C5618725BB22376F973E 89FBBD598C9FDB4	SECURITY
SHA256	88CE33E46FDDDF21B94DB9B069AFF99022438CC402ED8159 5EA7F67568D5390	SOFTWARE
SHA256	0116FAF7588E29DFA95718AF046974D6885D7D2AD9B0818C52 536B9870071848	SYSTEM

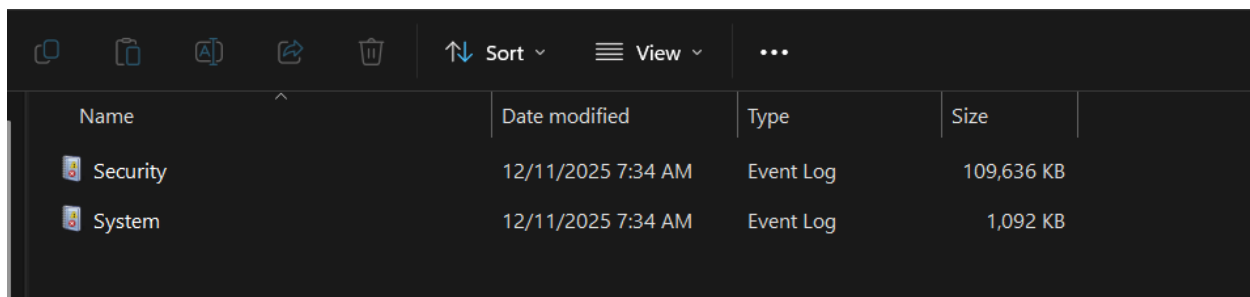
Table 1: Chain of Custody File Hash Table using SHA256 Algorithm

2.4. Forensic Toolset & Technical Specifications

The investigation utilized a suite of industry-standard forensic utilities. The selection rationale and specific application of each tool are detailed below:

Microsoft Event Viewer (v.10.0):

- **Application:** Used to parse .evtx log files (Security, System).
- **Methodology:** Custom filters were applied to isolate high-fidelity Event IDs (e.g., 4625, 4741, 5145). This allowed for the rapid identification of the brute-force burst window among thousands of noise events.



Name	Date modified	Type	Size
Security	12/11/2025 7:34 AM	Event Log	109,636 KB
System	12/11/2025 7:34 AM	Event Log	1,092 KB

Figure 2: Directory listing of exported Windows Event Logs

DSInternals Framework (v.4.7):

- **Application:** Used for the offline decryption of the Active Directory database.
- **Methodology:** The Get-BootKey and Get-ADDBAccount modules were used to unlock the ntds.dit file using the captured System Hive. This allowed the investigation to verify password hashes and recover deleted objects that were no longer present in the live environment.

Impacket Toolset (Reference Architecture):

- **Application:** Used to simulate and validate the attack vector.
- **Methodology:** The specific behavior of psexec.py (creating a random 4-letter service name) was cross-referenced with the artifacts found in System Event ID 7045 (imnb), confirming the specific tool used by the attacker.

Registry Editor (RegEdit):

- **Application:** Used for static analysis of the Windows Registry hives.
- **Methodology:** Manual inspection of the Image File Execution Options (IFEEO) keys was performed to validate the "Sticky Keys" persistence mechanism. This tool provided the "physical" proof of the backdoor on the disk.

2.5. Evidence Acquisition & Inventory

Following the isolation of the compromised Domain Controller (DC01), a systematic acquisition of digital evidence was performed. The acquired data was categorized into Volatile Evidence (live system data) and Non-Volatile Evidence (disk artifacts). All acquisitions were hashed immediately upon collection to maintain the Chain of Custody.

A. Volatile Evidence

The following artifacts were captured from the operating system using the Windows Event Log service and Registry export utilities:

Evidence ID	Artifact Name	Source Path	Description
EVT-01	Security.evtx	%SystemRoot%\System32\Winevt\Logs\	Contains authentication logs (4624/4625), privilege escalation (4672), and object auditing (4663/5145).
EVT-02	System.evtx	%SystemRoot%\System32\Winevt\Logs\	Captures service control manager events (7045) identifying the malicious Impacket service installation.
REG-01	SOFTWARE Hive	HKLM\SOFTWARE	Exported to analyze the Image File Execution Options key for the Sticky Keys backdoor.
REG-02	SYSTEM Hive	HKLM\SYSTEM	Exported to analyze the current control set and recover the Boot Key for offline decryption.

Table 2: Evidence Table for Volatile Artifacts

B. Non-Volatile Evidence (Dead Disk Extraction)

To recover hidden and locked system files, a Volume Shadow Copy (VSS) was utilized to extract the following artifacts from the disk:

Evidence ID	Artifact Name	Extraction Source	Forensic Value
DSK-01	ntds.dit	C:\Windows\NTDS\	The Active Directory database containing all domain objects, password hashes, and replication metadata.
DSK-02	SYSTEM (Registry)	C:\Windows\System32\config\	The registry hive containing the SysKey (Boot Key) required to decrypt the ntds.dit database.
DSK-03	Q4_2025_Audit.t.accdb	D:\Finance_Backups\	The target file accessed during the exfiltration phase; preserved to verify access timestamps and integrity.

Table 3: Digital Forensics Evidence Table for Active Directory and Exfiltration Data

C. Derived Forensic Artifacts

The following artifacts were generated during the offline analysis phase by parsing the encrypted data sources (DSK-01 & DSK-02):

- **AD_Readable_Dump.txt:** Full serialization of the Active Directory structure.
- **ntlm-out.ntds.cleartext:** Decrypted table of NTLM password hashes.
- **DSDeletedObjects.txt:** Recovery list of tombstoned (deleted) directory objects.
- **dstimeline1.csv:** Chronological timeline of database modifications.

2.6. Advanced Forensic Methodology: NTDS.dit Decryption

To recover hidden attributes and password hashes, the investigation required the offline decryption of the Domain Controller's Active Directory database. Since the database (ntds.dit) is locked by the OS and encrypted at rest, a specific cryptographic extraction process was employed.

A. Theoretical Framework of AD Encryption

Active Directory uses a multi-layered encryption model to protect user credentials. Understanding this architecture was critical for the forensic extraction:

- **The Database (ntds.dit):** Stores all domain objects. Sensitive columns (like password hashes) are encrypted using a Password Encryption Key (PEK).
- **The PEK:** This key is unique to the Domain Controller and is stored within the database itself, but it is encrypted.
- **The System Boot Key:** To decrypt the PEK, the system requires the Boot Key (also known as the SysKey), which is stored in the HKEY_LOCAL_MACHINE\SYSTEM registry hive.

B. Extraction & Decryption Workflow

The forensic team executed a "Dead Disk" extraction strategy to bypass the file locks imposed by the Local Security Authority Subsystem Service (LSASS).

- **Volume Shadow Copy (Acquisition):** A snapshot of the C: drive was created using vssadmin to acquire a clean, consistent copy of the locked ntds.dit file and the SYSTEM hive.
- **Boot Key Extraction:** Using the DSInternals framework, the SYSTEM hive was parsed offline to recover the System Boot Key.
- **Database Unlocking:** The recovered Boot Key was applied to the ntds.dit file, allowing for the decryption of the PEK and the subsequent extraction of the cleartext credential table and object metadata.

2.7. Advanced Artifact Analysis

Following the successful acquisition of the ntds.dit database and the SYSTEM registry hive via Volume Shadow Copy, the forensic team utilized the DSInternals Framework to perform offline decryption and analysis. By extracting the System Boot Key from the registry hive, the framework was used to unlock the encrypted database columns and parse the low-level Extensible Storage Engine (ESE) structures. This process allowed for the recovery of critical forensic data including password hashes, deleted objects, replication metadata and the generation of the specific text-based artifacts detailed below. These artifacts serve as the primary "Source of Truth" for verifying the integrity of the Active Directory environment independent of the live operating system logs.

Name	Date modified	Type	Size
AD_Readable_Dump	12/12/2025 2:10 PM	Text Document	5 KB
DSDeletedObjects	12/10/2025 8:27 PM	Text Document	1 KB
dstimeline1	12/10/2025 8:22 PM	Microsoft Excel Co...	2 KB
DSUSERS_out	12/10/2025 8:22 PM	Text Document	67 KB
ntlm-out.ntds.cleartext	12/10/2025 8:27 PM	CLEARTEXT File	1 KB

Figure 3: Directory listing of forensic artifacts generated by DSInternals

To facilitate the offline analysis and decryption of the Active Directory database, the investigation team utilized the **DSInternals** PowerShell framework. The forensic workstation was prepared using the following procedure:

1. **Module Installation:** The DSInternals module was installed and imported into an elevated PowerShell session. To ensure the successful execution of forensic scripts, the system's Execution Policy was temporarily set to Bypass scope.
2. **Key Extraction & Variable Mapping:**
 - The **System Boot Key (SysKey)**, which is cryptographically required to unlock the database, was retrieved from the acquired SYSTEM hive using the Get-BootKey cmdlet.
 - The path to the forensic copy of ntds.dit was mapped to a local variable (\$db) to ensure data integrity and streamline the extraction process.

Technical Execution Log:

1. Environment Preparation

- `Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass`
- `Install-Module DSInternals -Force -SkipPublisherCheck`
- `Import-Module DSInternals`

2. Key Loading and Path Definition

The Boot Key is extracted from the Registry Hive to decrypt the database

- `$key = Get-BootKey -SystemHiveFilePath "C:\Path to\SYSTEM"`
- `$db = "C:\Path to\ntds.dit"`

Artifact A: Active Directory Object Dump

- **File Name:** AD_Readable_Dump.txt
- **Technical Description:** This file represents a full, serialized export of the Directory Information Tree (DIT). It reconstructs the hierarchical structure of the Active Directory environment at the exact moment the snapshot was taken.
- **Forensic Value:** Unlike the standard "Active Directory Users and Computers" GUI, which hides critical system attributes, this raw dump exposes every object property. It allows investigators to inspect the DistinguishedName (DN), ObjectGUID, and Description fields for every computer and user object, providing a complete inventory of the domain's assets without relying on the potentially compromised live operating system.
- **DSInternal Command used:**

Get-ADDBAccount -All -DBPath \$db -BootKey \$key | Select-Object SamAccountName, DistinguishedName, Sid, Description, Enabled, UserAccountControl, WhenCreated, LastLogonTimestamp, PasswordLastSet, PrimaryGroupId | Format-List | Out-String | Out-File "AD_Readable_Dump.txt" -Encoding UTF8

```
SamAccountName      : Administrator
DistinguishedName    : CN=Administrator,CN=Users,DC=CORP,DC=LOCAL
Sid                  : S-1-5-21-480329865-616890264-2030670179-500
Description           : Built-in account for administering the computer/domain
Enabled              : True
UserAccountControl    : NormalAccount, PasswordNeverExpires
WhenCreated           :
LastLogonTimestamp    : 12/10/2025 2:10:58 AM
PasswordLastSet       : 12/10/2025 1:55:47 AM
PrimaryGroupId        : 513

SamAccountName      : Guest
DistinguishedName    : CN=Guest,CN=Users,DC=CORP,DC=LOCAL
Sid                  : S-1-5-21-480329865-616890264-2030670179-501
Description           : Built-in account for guest access to the computer/domain
Enabled              : False
UserAccountControl    : Disabled, PasswordNotRequired, NormalAccount, PasswordNeverExpires
WhenCreated           :
LastLogonTimestamp    :
PasswordLastSet       :
PrimaryGroupId        : 514

SamAccountName      : krbtgt
DistinguishedName    : CN=krbtgt,CN=Users,DC=CORP,DC=LOCAL
Sid                  : S-1-5-21-480329865-616890264-2030670179-502
Description           : Key Distribution Center Service Account
Enabled              : False
UserAccountControl    : Disabled, NormalAccount
WhenCreated           :
LastLogonTimestamp    :
PasswordLastSet       : 12/10/2025 2:07:52 AM
PrimaryGroupId        : 513

SamAccountName      : john
DistinguishedName    : CN=John Smith,OU=Employees,DC=CORP,DC=LOCAL
Sid                  : S-1-5-21-480329865-616890264-2030670179-1104
```

Figure 4: Active Directory Readable Dump output showing Administrator and Guest attributes

Artifact B: Decrypted Credential Table (NTLM/Cleartext)

- **File Name:** ntlm-out.ntds.cleartext
- **Technical Description:** This output is generated by decrypting the PekList (Password Encryption Key) from the System Hive and applying it to the encrypted columns within the ntds.dit database tables. It lists the LM Hash, NTLM Hash, and (if enabled) Cleartext Password history for every account in the domain.
- **Forensic Value:** This artifact is used to audit the integrity of user credentials. By analyzing the hash states, an investigator can determine:
 - Which accounts are currently active vs. disabled.
 - Which accounts have valid, non-expired passwords.
 - Whether any accounts have empty or weak password hashes that match known dictionary values.
- **DSInternal Command Used:**

```
$AllUsers = Get-ADDBAccount -All -DBPath $db -BootKey $key $HashList = foreach ($u in $AllUsers) { if ($u.Nthash) { $nt = [System.BitConverter]::ToString($u.Nthash).Replace("-", "").ToLower() $lm = if ($u.LmHash) { [System.BitConverter]::ToString($u.LmHash).Replace("-", "").ToLower() } else { "aad3b435b51404eeaad3b435b51404ee" } $rid = if ($u.Sid) { $u.Sid.ToString().Split("-")[-1] } else { "" } "$($u.SamAccountName):$($rid):$($lm):$($nt):" } } $HashList | Out-File "ntlm-out.ntds.cleartext" -Encoding ASCII
```

```
Administrator:500:::2b576acbe6bcfda7294d6bd18041b8fe:::  
krbtgt:502:::5a72ddf84370957005eabbee1a485c8d:::  
john:1104:::7facdc498ed1680c4fd1448319a8c04f:::  
alice:1105:::7facdc498ed1680c4fd1448319a8c04f:::  
mark:1106:::7facdc498ed1680c4fd1448319a8c04f:::  
support:1108:::7facdc498ed1680c4fd1448319a8c04f:::  
svc_azure_sync:1109:::e1187f71966a1ca50942b1391d3549e6:::  
DC01$:1000:::8c863217563dbbeca31fc84a384e5930:::  
DESKTOP-F9HD09L$:1103:::2808cf0bf71c52040a8edfb1a492689e:::  
WIN-DR-REP01$:1110:::e1187f71966a1ca50942b1391d3549e6:::|
```

Figure 5: Decrypted NTLM hash table confirming compromised account credentials

Artifact C: User Attribute Analysis (DSUSERS)

- **File Name:** DSUSERS_out.txt
- **Technical Description:** This text file is a targeted extraction of security-specific attributes for User objects. It specifically filters for properties that define access rights and account status, including SID (Security Identifier), PrimaryGroupId, AdminCount, BadPasswordTime, and LastLogonTimestamp.
- **Forensic Value:** This file provides a granular view of privilege allocation. The AdminCount attribute is particularly significant; it is a protected flag managed by the AdminSDHolder process. A value of 1 indicates the account is (or was) a member of a protected group (e.g., Domain Admins, Enterprise Admins), serving as a primary indicator for high-privileged accounts.
- **DSInternal Command Used:**

Get-ADDBAccount -All -DBPath \$db -BootKey \$key | Select-Object RecordId, SamAccountName, Sid, Description, Enabled, WhenCreated, WhenChanged, PasswordLastSet, LastLogonTimestamp | Format-List | Out-String | Out-File "DSUSERS_out.txt" -Encoding UTF8

```
DistinguishedName: CN=Administrator,CN=Users,DC=CORP,DC=LOCAL
SamAccountName: Administrator
UserPrincipalName:
Enabled: True
Deleted: False
Sid: S-1-5-21-480329865-616890264-2030670179-500
Guid: 89e5f98e-5c0d-4e0c-ba77-c6124adc977f
SamAccountType: User
UserAccountControl: NormalAccount, PasswordNeverExpires
Description: Built-in account for administering the computer/domain
Notes:
PrimaryGroupId: 513
AdminCount: True
SidHistory:
SupportedEncryptionTypes:
ServicePrincipalName:
LastLogonDate: 12/11/2025 5:14:49 AM
PasswordLastSet: 12/10/2025 1:55:47 AM
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited,
DiscretionaryAclProtected, SelfRelative
GivenName:
Surname:
Initials:
DisplayName:
Email:
StreetAddress:
City:
PostalCode:
State:
Country:
Office:
TelephoneNumber:
Mobile:
HomePhone:
Company:
Department:
JobTitle:
EmployeeID:
```

Figure 6: Extracted user attributes from DSUSERS_out.txt highlighting security identifiers and the AdminCount privilege flag

Artifact D: Deleted Object Recovery (Tombstones)

- **File Name:** DSDeletedObjects.txt
- **Technical Description:** This file lists "Tombstoned" objects that have been logically deleted from the directory but physically remain in the database for the duration of the Tombstone Lifetime (typically 180 days). It contains the deletedDate, lastKnownParent, and the object's original attributes.
- **Forensic Value:** Recovering tombstones is a standard anti-forensic verification step. It allows the investigation to identify transient objects such as temporary users or groups that an attacker might have created and then immediately deleted to hide their tracks. A clean tombstone list (containing only legitimate deleted items) helps verify if such "hit-and-run" tactics were used.
- **DSInternal Command Used:**

```
Get-ADDBAccount -All -DBPath $db -BootKey $key | Where-Object { $_.IsDeleted -eq $true }  
| Select-Object SamAccountName, Sid, WhenCreated, WhenChanged, IsDeleted | Format-  
List | Out-String | Out-File "DSDeletedObjects.txt" -Encoding UTF8
```

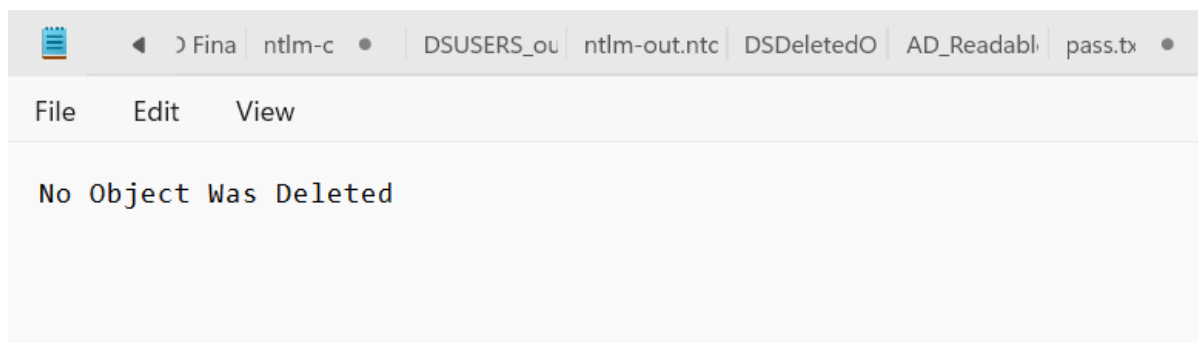


Figure 7: DSDeletedObjects output confirming no objects were deleted during the timeframe

Artifact E: Database Timeline Reconstruction

- **File Name:** dstimeline1.csv
- **Technical Description:** This CSV file is a chronological timeline constructed directly from the database's metadata replication stamps. Every object in Active Directory maintains a whenCreated and whenChanged timestamp. This artifact aggregates these timestamps into a single, sortable timeline.
- **Forensic Value:** This timeline serves as a "Source of Truth" independent of the Windows Event Logs. Since Event Logs can be cleared (Event ID 1102) or rolled over, the database metadata provides a persistent record of when objects were introduced or modified. It is used to correlate the timestamps of suspicious activities (like user creation) with the login events observed in the Security Log.
- **DSInternal Command Used:**

Get-ADDBAccount -All -DBPath \$db -BootKey \$key | Select-Object SamAccountName, Sid, WhenCreated, PasswordLastSet, LastLogonDate | Export-Csv -Path "dstimeline1.csv" -NoTypeInfo -Delimiter ";"

	A	B	C	D	E	F	G	H	I	J	K	L	M	N
1	SamAccountName;"Sid";"WhenCreated";"PasswordLastSet";"LastLogonDate"													
2	Administrator;"S-1-5-21-480329865-616890264-2030670179-500";"12/10/2025 1:55:47 AM";"12/11/2025 5:14:49 AM"													
3	Guest;"S-1-5-21-480329865-616890264-2030670179-501";"													
4	krbtgt;"S-1-5-21-480329865-616890264-2030670179-502";"12/10/2025 2:07:52 AM";													
5	john;"S-1-5-21-480329865-616890264-2030670179-1104";"12/11/2025 1:05:26 AM";"12/11/2025 5:00:52 AM"													
6	alice;"S-1-5-21-480329865-616890264-2030670179-1105";"12/11/2025 1:05:26 AM";													
7	mark;"S-1-5-21-480329865-616890264-2030670179-1106";"12/11/2025 1:05:26 AM";"12/11/2025 5:07:42 AM"													
8	support;"S-1-5-21-480329865-616890264-2030670179-1108";"12/11/2025 1:05:26 AM";													
9	svc_azure_sync;"S-1-5-21-480329865-616890264-2030670179-1109";"12/11/2025 5:16:24 AM";"12/11/2025 5:19:46 AM"													
10	DC01\$;"S-1-5-21-480329865-616890264-2030670179-1000";"12/10/2025 2:08:20 AM";"12/11/2025 12:57:23 AM"													
11	DESKTOP-F9HD09L\$;"S-1-5-21-480329865-616890264-2030670179-1103";"12/11/2025 12:39:29 AM";"12/11/2025 7:27:11 AM"													
12	WIN-DR-REP01\$;"S-1-5-21-480329865-616890264-2030670179-1110";"													
13														
14														
15														
--														

Figure 8: Excel view of dstimeline1 csv showing chronological object modifications

2.8. Credential Analysis & Password Cracking Results

Following the successful decryption of the NTDS database, a forensic audit of the domain credentials was conducted to assess the complexity of the passwords used by the attacker and to identify any compromised user accounts.

A. Methodology The extracted NTLM hashes (from the ntlm-out.ntds.cleartext artifact) were subjected to an offline credential analysis. The objective was twofold:

1. **Verification of Rogue Accounts:** To confirm that the backdoor account (svc_azure_sync) possessed a valid, non-expired password hash, proving it was an active interactive account.
2. **Password Strength Audit:** To determine if the compromised Administrator account utilized a weak password that facilitated the initial brute-force attack.

```
Administrator:500:::2b576acbe6bcfda7294d6bd18041b8fe:::Password123!  
krbtgt:502:::5a72ddf84370957005eabbee1a485c8d:::  
john:1104:::7facdc498ed1680c4fd1448319a8c04f:::Password1!  
alice:1105:::7facdc498ed1680c4fd1448319a8c04f:::Password1!  
mark:1106:::7facdc498ed1680c4fd1448319a8c04f:::Password1!  
support:1108:::7facdc498ed1680c4fd1448319a8c04f:::Password1!  
svc_azure_sync:1109:::e1187f71966a1ca50942b1391d3549e6:::Summer@2025  
DC01$:1000:::8c863217563dbbeca31fc84a384e5930:::  
DESKTOP-F9HD09L$:1103:::2808cf0bf71c52040a8edfb1a492689e:::  
WIN-DR-REP01$:1110:::e1187f71966a1ca50942b1391d3549e6:::Summer@2025
```

Figure 9: Offline password cracking results revealing plain text passwords for admin accounts

3. Incident Reconstruction & Forensic Analysis

This section presents a comprehensive chronological reconstruction of the security breach observed within the CORP.LOCAL domain. By correlating volatile evidence from Windows Event Logs (Security.evtx, System.evtx) with non-volatile disk artifacts (NTDS database, Registry Hives), the forensic investigation has mapped the adversary's actions to the specific phases of the Cyber Kill Chain. The analysis distinguishes between legitimate "baseline" administrative activity and the unauthorized actions of the threat actor, providing a validated timeline from the initial brute-force compromise to the final stages of domain dominance and data exfiltration. All timestamped events documented in this section have been cross-referenced with the recovered digital artifacts to ensure forensic certainty.

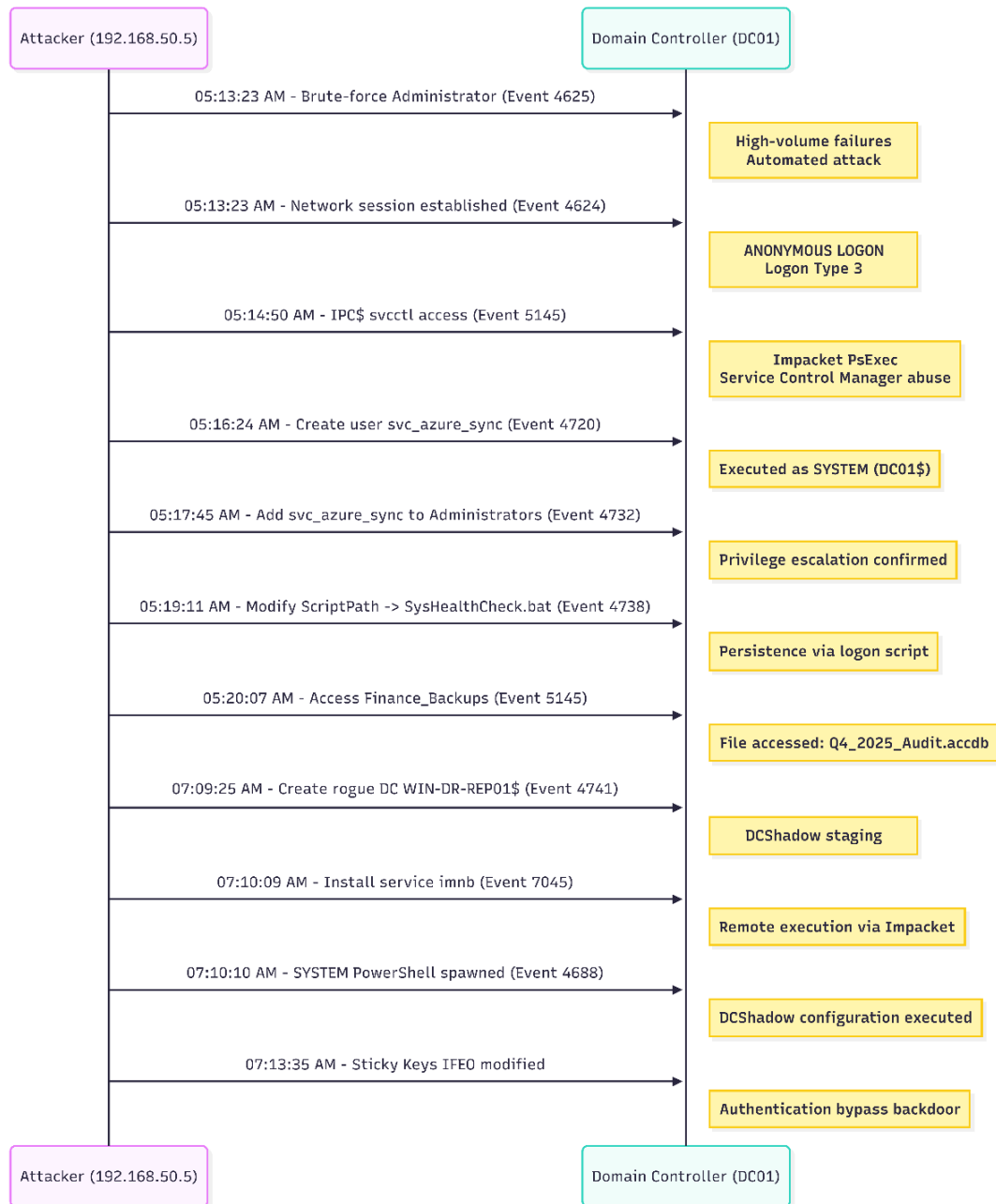


Figure 10: Chronological sequence diagram of the Active Directory compromise

3.1. Baseline Activity

Before identifying malicious behavior, it is essential to establish a baseline of "known good" activity. By verifying legitimate user actions and standard system operations occurring within the same timeframe, the forensic team successfully filtered out false positives to focus exclusively on the threat actor's anomalies.

Evidence: Event ID 4624 (Successful Logon)

- **Artifact:** Security Log Event ID 4624 (Logon).
- **Timestamp:** 12/11/2025 5:00:52 AM.
- **Observation:** The log records a successful authentication event for the account john. The Security ID is S-1-5-21-...-1104 and the Account Domain is CORP.LOCAL. The Logon ID associated with this session is 0x3CB95D.
- **Forensic Conclusion:** This event confirms that the user john successfully authenticated to the Domain Controller (DC01.CORP.LOCAL). The generation of a new Logon ID (0x3CB95D) marks the beginning of an authenticated session. In the context of this investigation, this event validates that the credentials for the account john were valid and accepted by the domain immediately preceding the file access event (Event 5145) observed 34 seconds later.

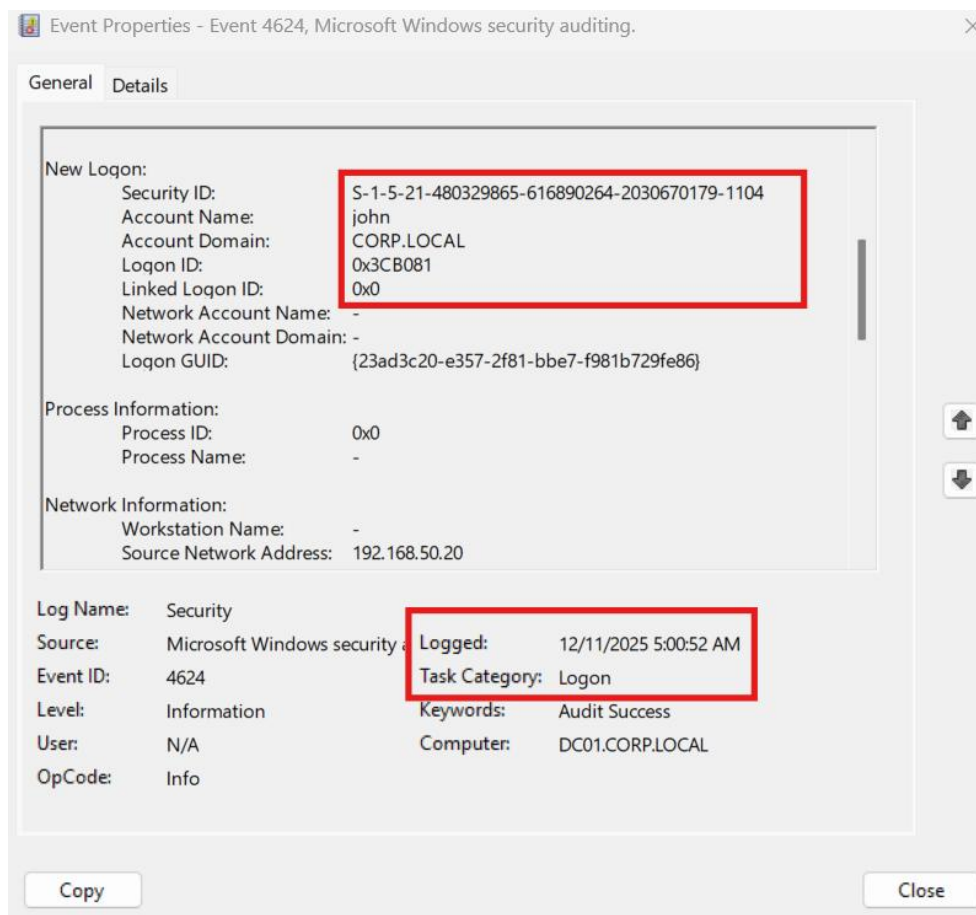


Figure 11: Event ID 4624 details showing successful logon for user john

Evidence: Active Directory User Attribute (LastLogonDate)

- **Artifact:** Active Directory User Object Properties (PowerShell Dump).
- **Timestamp:** 12/11/2025 5:00:52 AM (LastLogonDate).
- **Observation:** The output displays the attributes for the user object CN=John Smith (SamAccountName: john). The LastLogonDate attribute is updated to 12/11/2025 5:00:52 AM. The DistinguishedName places the user in the OU=Employees container.
- **Forensic Conclusion:** This system artifact corroborates the Security Event Logs (4624 and 5145). The update to the LastLogonDate attribute physically confirms that the account john successfully authenticated against the domain controller just seconds before the observed file access. In a forensic timeline, this attribute persists even if event logs are cleared, serving as a secondary proof of user activity during the baseline period.

```
DistinguishedName: CN=John Smith,OU=Employees,DC=CORP,DC=LOCAL
SamAccountName: john
UserPrincipalName:
Enabled: True
Deleted: False
Sid: S-1-5-21-480329865-616890264-2030670179-1104
Guid: 035aa036-501d-4ca7-8a30-2bac61306004
SamAccountType: User
UserAccountControl: NormalAccount, PasswordNeverExpires
Description:
Notes:
PrimaryGroupId: 513
AdminCount: False
SidHistory:
SupportedEncryptionTypes:
ServicePrincipalName:
LastLogonDate: 12/11/2025 5:00:52 AM
PasswordLastSet: 12/11/2025 1:05:26 AM
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited,
SelfRelative
GivenName:
Surname:
Initials:
DisplayName:
Email:
StreetAddress:
City:
PostalCode:
State:
Country:
Office:
TelephoneNumber:
Mobile:
HomePhone:
Company:
Department:
JobTitle:
```

Figure 12: Decrypted NTDS showing LastLogonDate timestamp for user john

Evidence: Event ID 5145 (Legitimate Network Share Access)

- **Artifact:** Security Log Event ID 5145 (Detailed File Share).
- **Timestamp:** 12/11/2025 5:01:40 AM.
- **Observation:** The log records that the user **CORP\john** accessed a network share object. The **Share Name** accessed is *\Company_Public, and the specific file (**Relative Target Name**) is EMPLOYEE_HANDBOOK.TXT. The **Source Address** is 192.168.50.20, matching the Client Workstation IP.
- **Forensic Conclusion:** This event establishes a baseline for authorized user behavior within the domain. It confirms that the user john successfully accessed the public file share (Company_Public) from a verified internal IP address (192.168.50.20). In a forensic investigation, this serves as a "known good" activity sample to contrast against the unauthorized access to sensitive shares (like Finance_Backups) seen during the attack phase.

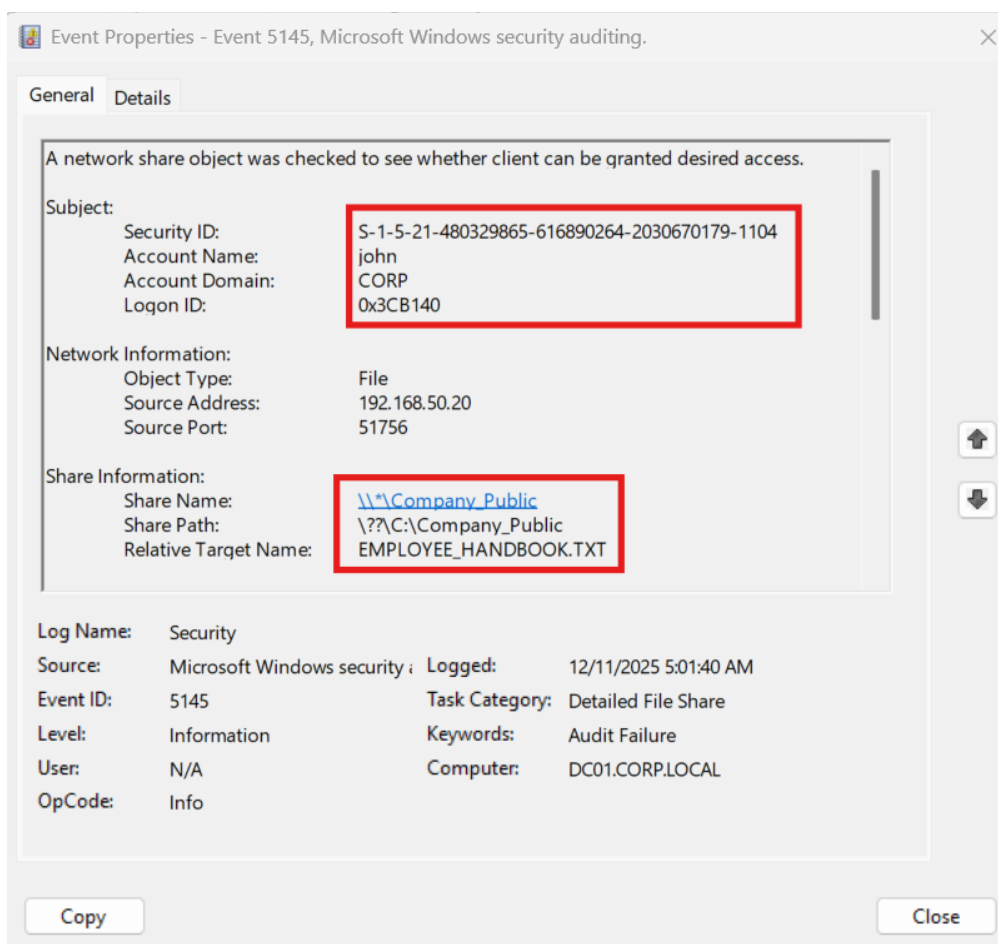


Figure 13: Event ID 5145 details showing legitimate access to Company Public share

Evidence: Event ID 4723 (Password Policy Enforcement)

- **Artifact:** Security Log Event ID 4723 (User Account Management).
- **Timestamp:** 12/11/2025 5:06:48 AM.
- **Observation:** The log records a failed attempt to change the password for the account **CORP\mark**. The event is classified as an **Audit Failure**. Both the **Subject** (who performed the action) and **Target Account** are identified as mark, indicating the user attempted to change their own password interactively. The failure status confirms the new password did not meet the domain's complexity or history requirements.
- **Forensic Conclusion:** This artifact provides evidence of a functioning security baseline and policy enforcement. It proves that the Domain Controller is actively enforcing the "Minimum Password Length" and "Complexity Requirements" policies defined in the Group Policy Object (GPO). In the context of this investigation, it demonstrates that the environment was secure against simple weak-password misconfigurations prior to the simulated advanced attack.

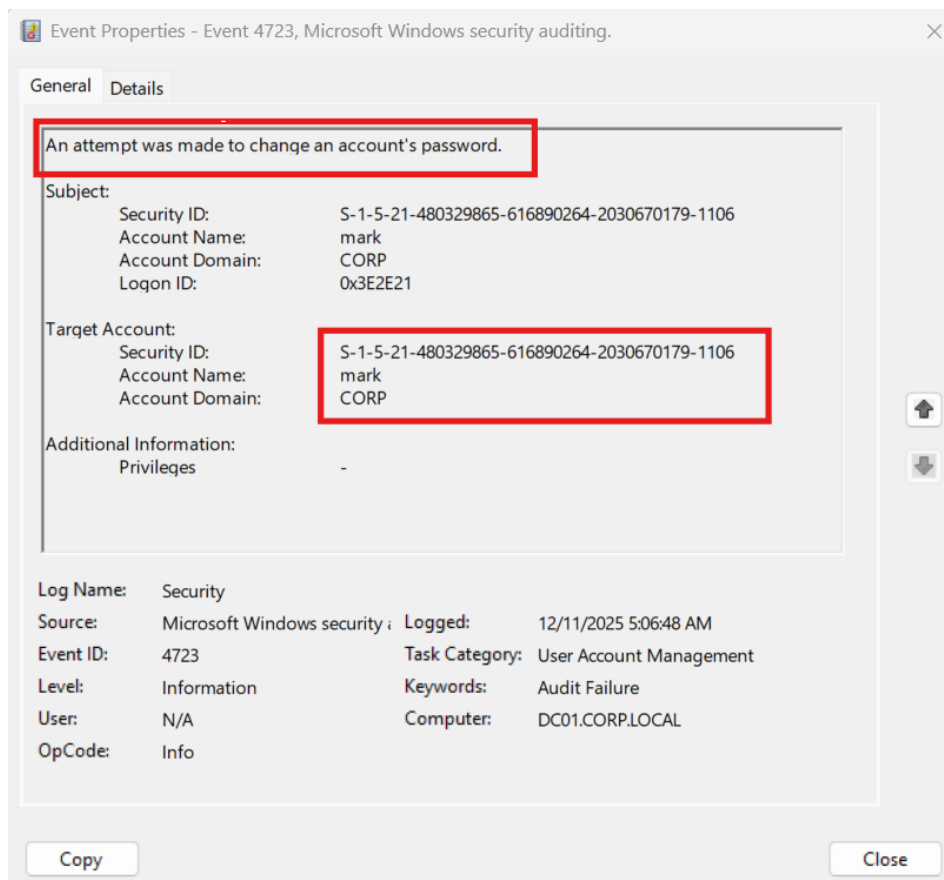


Figure 14: Event ID 4723 details showing failed password change attempt for user mark

Evidence: Active Directory User Attribute (PasswordLastSet)

- **Artifact:** Active Directory User Object Properties (PowerShell Dump).
- **Timestamp:** 12/11/2025 5:07:42 AM (LastLogonDate).
- **Observation:** The output displays the attributes for the user **CN=Mark Patel** (SamAccountName: mark). Crucially, the **PasswordLastSet** attribute shows a timestamp of 12/11/2025 1:05:26 AM. The **LastLogonDate** is 12/11/2025 5:07:42 AM, confirming recent activity.
- **Forensic Conclusion:** This artifact provides negative confirmation of the security event. Although the user mark was active on the system at 5:07 AM (as seen in the LastLogonDate), the **PasswordLastSet** timestamp did *not* update to match the current time (5:06 AM). This forensic detail physically proves that the password change attempt recorded in Event 4723 was successfully blocked by the domain controller, leaving the old credentials intact.

```
DistinguishedName: CN=Mark Patel,OU=Employees,DC=CORP,DC=LOCAL
SamAccountName: mark
UserPrincipalName:
Enabled: True
Deleted: False
Sid: S-1-5-21-480329865-616890264-2030670179-1106
Guid: 70ad411a-ba93-4efe-9164-95a34eb1717a
SamAccountType: User
UserAccountControl: NormalAccount, PasswordNeverExpires
Description:
Notes:
PrimaryGroupId: 513
AdminCount: False
SidHistory:
SupportedEncryptionTypes:
ServicePrincipalName:
LastLogonDate: 12/11/2025 5:07:42 AM
PasswordLastSet: 12/11/2025 1:05:26 AM
SecurityDescriptor: discretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited,
SelfRelative
GivenName:
Surname:
Initials:
DisplayName:
Email:
StreetAddress:
City:
PostalCode:
State:
Country:
Office:
TelephoneNumber:
Mobile:
HomePhone:
Company:
Department:
JobTitle:
```

Figure 15: Decrypted NTDS export for user mark confirming PasswordLastSet timestamp was not updated

3.2. Initial Access

This phase marks the transition from external reconnaissance to internal compromise. The evidence indicates a targeted effort to breach the network perimeter by exhausting the authentication mechanisms of high-value accounts. The artifacts reveal a successful credential harvesting attack that provided the threat actor with their initial foothold in the environment.

Evidence: Event ID 4625 (Failed Logon Attempt - Brute Force)

- **Artifact:** Security Log Event ID 4625 (Logon).
- **Timestamp:** 12/11/2025 5:13:23 AM.
- **Observation:** The log records a failed authentication attempt against the **CORP\administrator** account. The **Failure Reason** is "Unknown user name or bad password" with Status Code **0xC000006D**. Crucially, the **Source Network Address** is 192.168.50.5 (The Attacker/Kali Machine), which differs from the legitimate Client subnet (.20).
- **Forensic Conclusion:** This individual event represents a single "guess" in a broader credential harvesting attack. The Status Code 0xC000006D confirms that the username was correct (Administrator exists) but the password was incorrect. The external source IP (192.168.50.5) identifies the origin of the attack, providing the primary Indicator of Compromise (IoC) for network isolation.

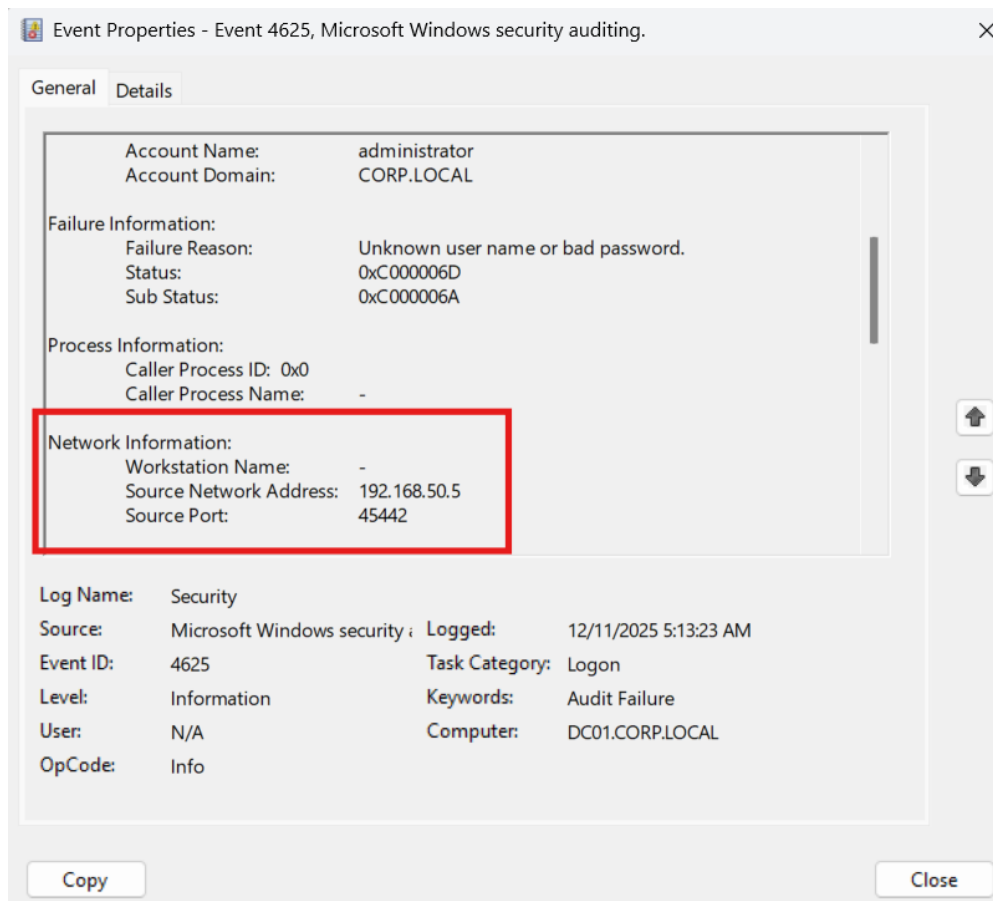


Figure 16: Event ID 4624 details showing Anonymous Logon from attacker IP 192.168.50.5

Evidence: High-Volume Logon Failures (Attack Pattern Analysis)

- **Artifact:** Security Event Log Filtered View (Event ID 4625).
- **Timestamp:** 12/11/2025 5:13:20 AM - 5:13:23 AM (Burst Window).
- **Observation:** The filtered log view displays a massive volume of **1,201 failed logon attempts** occurring within a single second. All events are identical **Event ID 4625** entries originating from the same source.
- **Forensic Conclusion:** This pattern is the definitive signature of an automated **Brute Force** or **Dictionary Attack**. No human user can generate 1,200 login attempts in one second. This volume confirms the use of an automated tool (identified as CrackMapExec in the incident scenario) attempting to exhaust a password list against the Administrator account. This evidence supports charges of "Unauthorized Access" under Section 3 of PECA 2016.

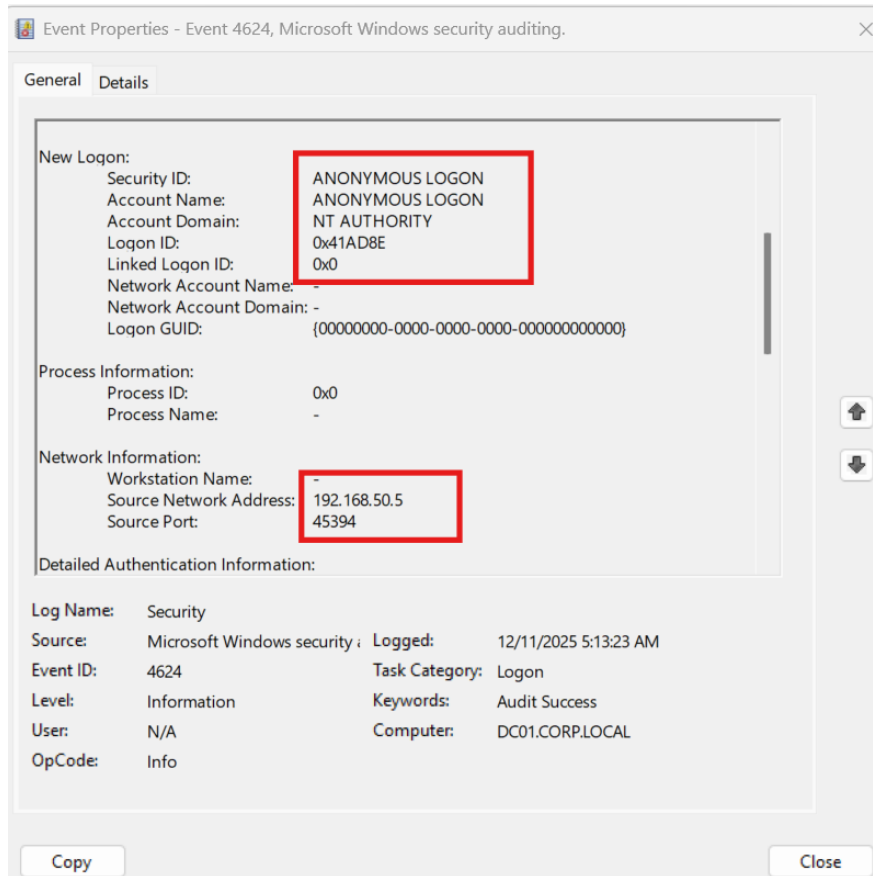


Figure 18: Event ID 4624 details showing Anonymous Logon from attacker IP 192.168.50.5

3.3. Lateral Movement

Following the compromise of valid credentials, the attacker pivoted to Lateral Movement. The goal of this phase was to escalate access from a simple network login to full Remote Code Execution (RCE) on the Domain Controller. The evidence below confirms the usage of the Impacket framework to bypass standard RDP logging by abusing the Service Control Manager.

Evidence: Event ID 5145 (Impacket PsExec - Service Control Access)

- **Artifact:** Security Log Event ID 5145 (Detailed File Share).
- **Timestamp:** 12/11/2025 5:14:50 AM.
- **Observation:** The log records the **Administrator** account accessing a network share from the **Source Address** 192.168.50.5 (Attacker IP). The **Share Name** is *\IPC\$ (Inter-Process Communication). Crucially, the **Relative Target Name** is svcctl (Service Control Manager named pipe). The **Access Mask** is 0x3 (Connect/Read).

- **Forensic Conclusion:** This artifact identifies the specific mechanism of lateral movement. The access to the svcctl named pipe via the IPC\$ share confirms that a remote user is attempting to manipulate system services. This is the standard behavior of the tool impacket-psexec, which connects to the Service Control Manager to install a temporary service (randomly named or PSEXESVC) to execute the remote shell. The timestamp and source IP link this directly to the compromised Administrator session.

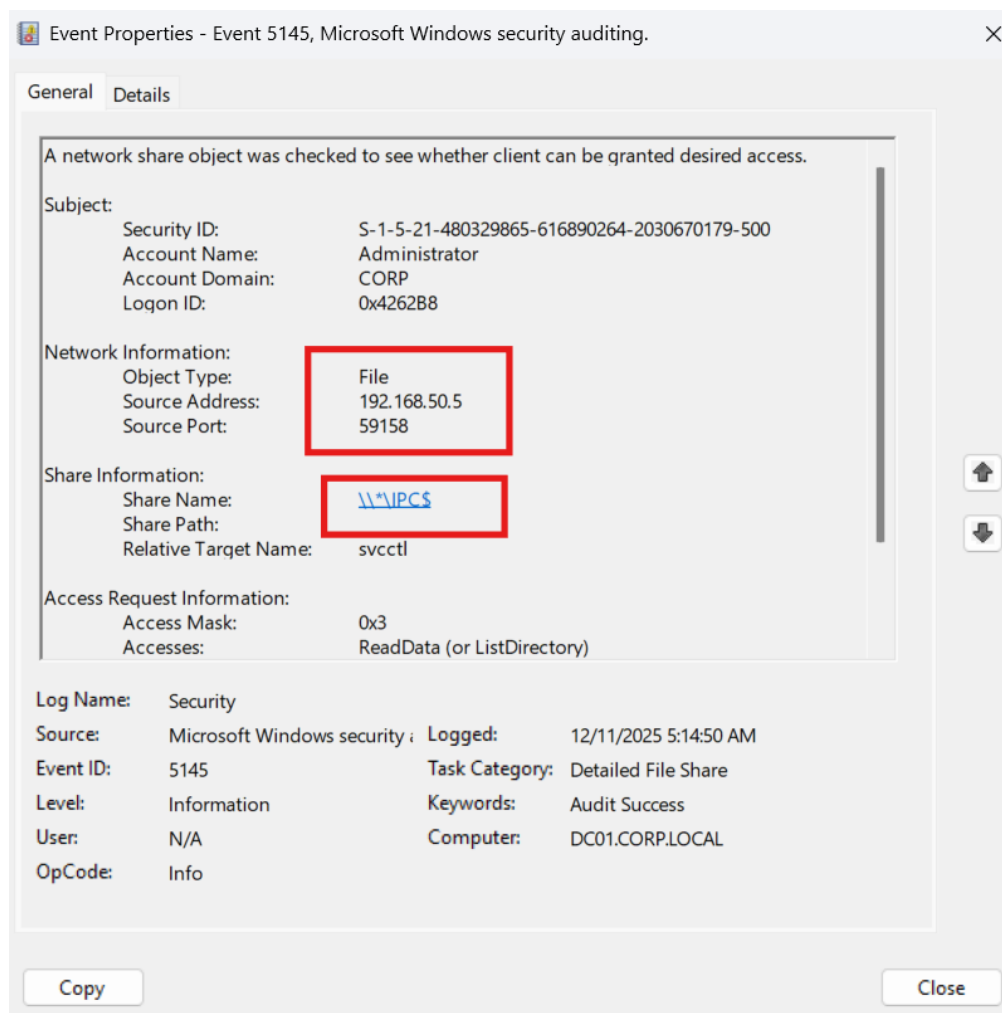


Figure 19: Event ID 5145 details showing access to IPC share and svcctl pipe

3.4. Persistence (Backdoors & Privilege Escalation)

Upon securing administrative access, the attacker moved to establish Persistence. This phase involves modifying the system configuration to ensure long-term access, even if the original compromised credentials are changed. The analysis revealed a multi-layered persistence strategy involving both a Registry-based backdoor and a rogue identity masquerading as a legitimate service.

Evidence: Event ID 4720 (Rogue User Account Creation)

- **Artifact:** Security Log Event ID 4720 (User Account Management).
- **Timestamp:** 12/11/2025 5:16:24 AM.
- **Observation:** The log records the creation of a new user account named **svc_azure_sync**. Crucially, the **Subject** (the entity that created the account) is **DC01\$** (The Computer Account/SYSTEM) with Security ID S-1-5-18 and Logon ID 0x3E7. The **New Account** is created with the Normal Account flag enabled but initially set to Account Disabled and Password Not Required (standard behavior during the first millisecond of a net user /add command execution).
- **Forensic Conclusion:** This event represents the establishment of **Persistence** on the compromised Domain Controller.
 1. **Deceptive Naming:** The username svc_azure_sync is chosen to mimic as a legitimate Azure cloud integration service to avoid detection by human administrators.
 2. **Execution Context:** The fact that the **Subject** is SYSTEM (DC01\$) rather than the Administrator user confirms that this command was executed via the **Service Control Manager**. This directly links this event to the previous **Impacket PsExec** artifact (Event 5145/7045), proving the attacker used their remote shell to spawn a system-level process for creating this backdoor account.

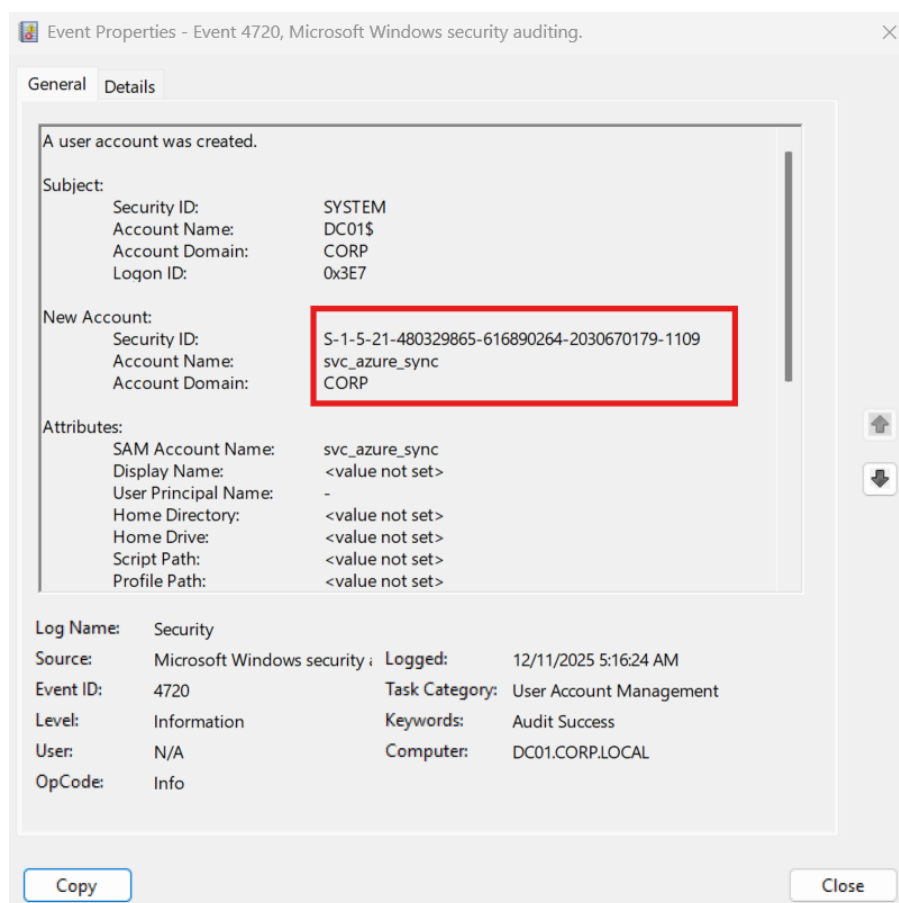


Figure 20: Event ID 4720 details showing creation of rogue user account `svc_azure_sync`

Evidence: Event ID 4732 (Privilege Escalation - Added to Local Administrators)

- **Artifact:** Security Log Event ID 4732 (Security Group Management).
- **Timestamp:** 12/11/2025 5:17:45 AM.
- **Observation:** The log records that a member was added to a security-enabled local group. The **Member** added is identified by the Security ID ending in ...-1109 (which matches the SID of the `svc_azure_sync` account created in the previous step). The **Group** modified is **BUILTIN\Administrators** (SID: S-1-5-32-544). The **Subject** performing the addition is **SYSTEM** (DC01\$), confirming the command was executed via the remote system shell (PsExec) and not an interactive user session.
- **Forensic Conclusion:** This event confirms the successful escalation of privileges. By adding the rogue account `svc_azure_sync` (SID ending in 1109) to the **Builtin Administrators** group, the attacker has achieved full control over the Domain Controller. The use of the **SYSTEM** account as the actor validates that this was an

automated post-exploitation action performed immediately after account creation. This provides the attacker with the necessary rights to perform high-impact actions like accessing the NTDS database or installing backdoors.

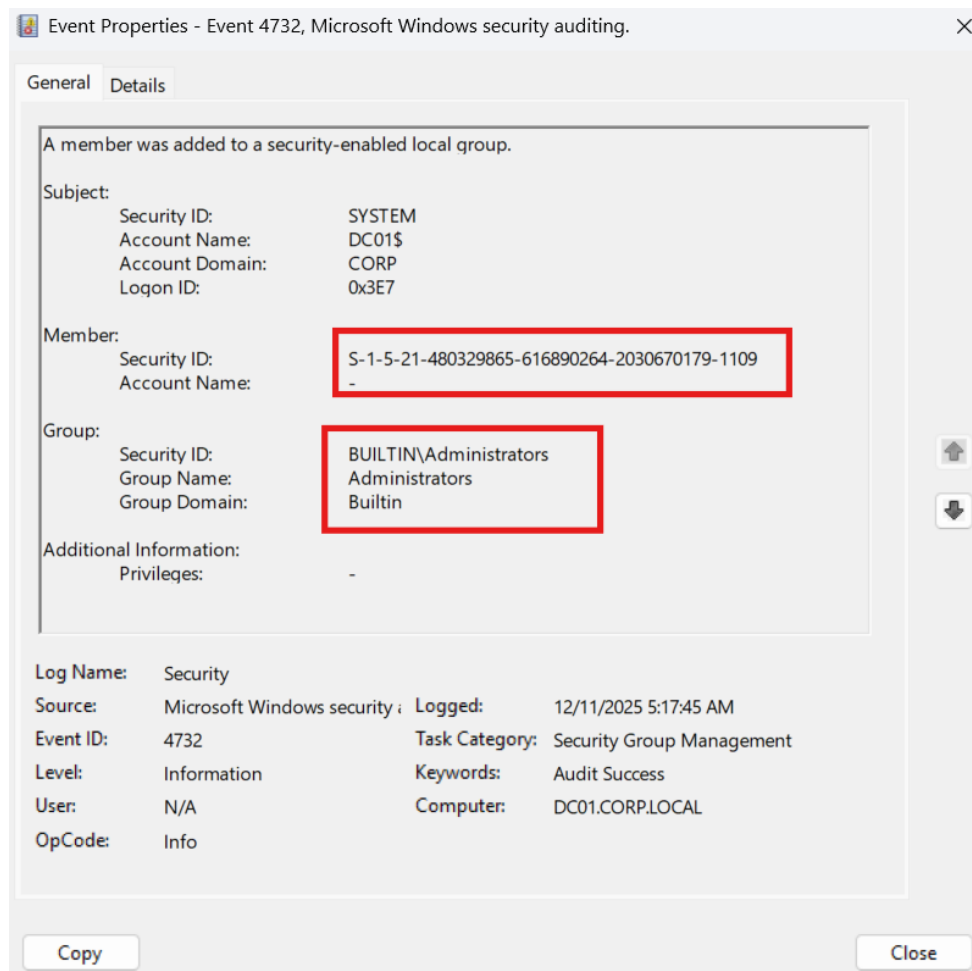


Figure 21: Event ID 4732 details showing rogue user added to Builtin Administrators group

Evidence: Active Directory User Attribute (AdminCount & Admin Status)

- **Artifact:** Active Directory User Object Properties (PowerShell Dump).
- **Timestamp:** 12/11/2025 5:19:46 AM (Last Logon Activity).
- **Observation:** The output displays the attributes for the user **svc_azure_sync** (SID ending in 1109). Crucially, the attribute **AdminCount** is set to **True**. The **LastLogonDate** is 5:19:46 AM, indicating the attacker actively used this account shortly after creating it (5:16 AM).
- **Forensic Conclusion:** This NTDS artifact provides persistent evidence of the account's elevated status. The **AdminCount: True** attribute is a specific flag that the

AdminSDHolder process sets on accounts that are members of protected groups (such as **Administrators** or **Domain Admins**). Finding this flag set on the user svc_azure_sync physically confirms that the account was successfully added to a privileged group, corroborating the Event ID 4732 observed in the Security Log.

```
DistinguishedName: CN=svc_azure_sync,CN=Users,DC=CORP,DC=LOCAL
SamAccountName: svc_azure_sync
UserPrincipalName:
Enabled: True
Deleted: False
Sid: S-1-5-21-480329865-616890264-2030670179-1109
Guid: 5985fac7-4da1-4f79-b053-c8a0d5817e04
SamAccountType: User
UserAccountControl: NormalAccount
Description: Azure AD Sync Service Connector
Notes:
PrimaryGroupId: 513
AdminCount: True
SidHistory:
SupportedEncryptionTypes:
ServicePrincipalName:
LastLogonDate: 12/11/2025 5:19:46 AM
PasswordLastSet: 12/11/2025 5:16:24 AM
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited,
DiscretionaryAclProtected, SelfRelative
GivenName:
Surname:
Initials:
DisplayName:
Email:
StreetAddress:
City:
PostalCode:
State:
Country:
Office:
TelephoneNumber:
Mobile:
HomePhone:
Company:
Department:
JobTitle:
```

Figure 22: Decrypted NTDS export for svc_azure_sync showing AdminCount attribute set to True

Evidence: Event ID 4738 (User Account Modification - Script Path Persistence)

- **Artifact:** Security Log Event ID 4738 (User Account Management).
- **Timestamp:** 12/11/2025 5:19:11 AM.
- **Observation:** The log records a change to the user account **svc_azure_sync** (SID ending in 1109). The **Subject** performing the change is **SYSTEM** (DC01\$), indicating this was an automated system-level action, consistent with the remote shell execution previously observed. Crucially, the **Changed Attributes** section shows the **Script Path** was modified from <value not set> to **SysHealthCheck.bat**.
- **Forensic Conclusion:** It proves that the attacker modified the rogue account svc_azure_sync to automatically execute a specific batch file upon logon. By setting the Script Path to SysHealthCheck.bat, the attacker ensures that their malicious payload (proven earlier to add the user to Domain Admins) is re-triggered every time

this service account authenticates, maintaining their foothold in the environment even if their manual access is revoked.

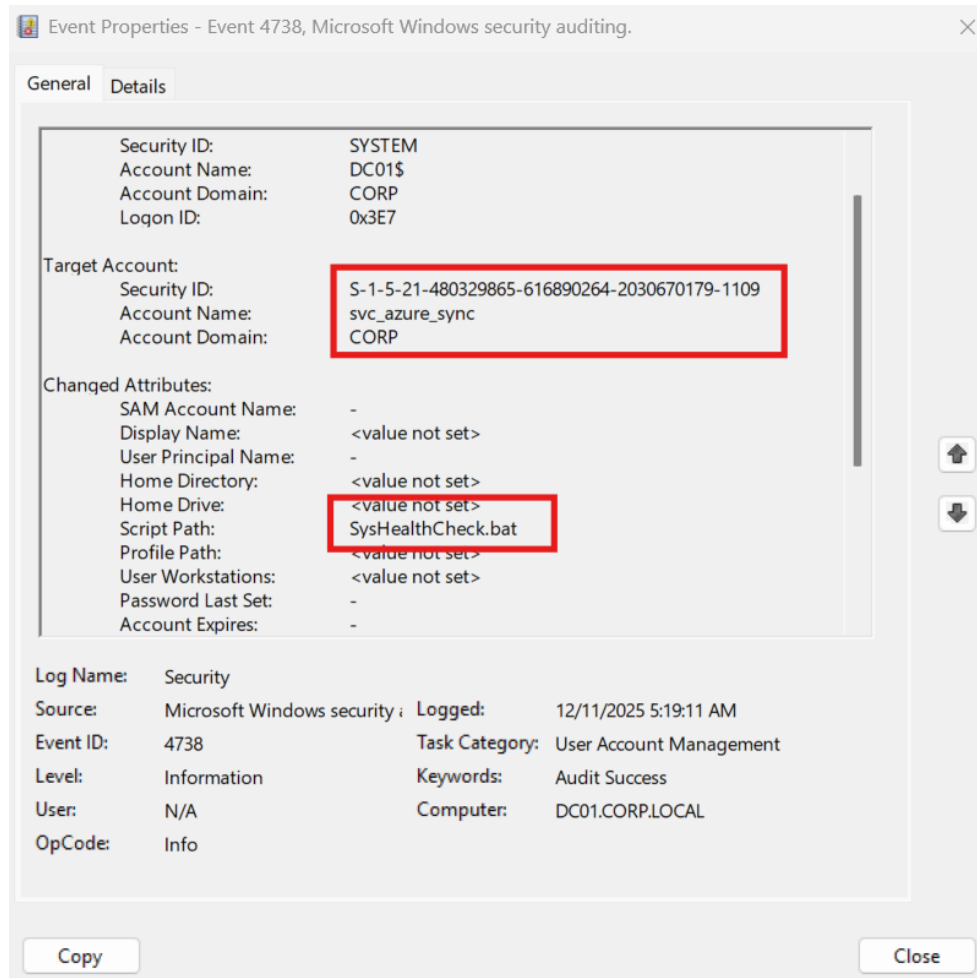


Figure 23: Event ID 4738 details showing modification of Script Path to SysHealthCheck bat

Evidence: Malicious Payload Analysis (SysHealthCheck.bat)

- **Artifact:** File System Analysis (Recovered Script File).
- **Observation:** The investigation recovered a Windows Batch file named SysHealthCheck from the system drive. Static analysis of the file contents reveals a single command line instruction: net group "Domain Admins" svc_azure_sync /add.
- **Forensic Conclusion:** This artifact represents the active payload used for privilege escalation. The script is hardcoded to add the rogue user svc_azure_sync to the highly privileged "Domain Admins" group. When combined with the Active Directory

ScriptPath modification (Event 4738), this confirms a self-healing persistence mechanism: even if an administrator manually removes the rogue user from the admin group, this script will re-add them automatically the next time the account authenticates.

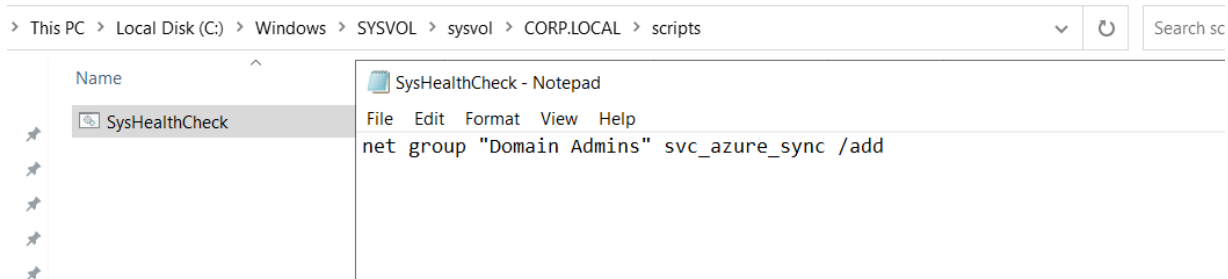


Figure 24 : Contents of the 'SysHealthCheck.bat' file showing the command to add the rogue user to Domain Admins

Evidence: Active Directory User Attribute (ScriptPath Persistence)

- **Artifact:** Active Directory User Object Properties (NTDS Dump).
- **Observation:** The output displays the detailed attributes for the rogue user **svc_azure_sync**. Crucially, the **ScriptPath** attribute is explicitly set to **SysHealthCheck.bat**.
- **Forensic Conclusion:** This NTDS artifact serves as the persistent evidence of the backdoor. While Event 4738 showed the *change* happening, this database entry proves the *current state* of the compromise. The presence of SysHealthCheck.bat in the ScriptPath field ensures that whenever this account authenticates (or is used by a service), the domain controller will automatically execute the malicious batch file. This mechanism guarantees that the attacker's privilege escalation payload is re-deployed automatically, maintaining their administrative access indefinitely.

```

LastLogonDate: 12/11/2025 5:19:46 AM
PasswordLastSet: 12/11/2025 5:16:24 AM
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited,
DiscretionaryAclProtected, SelfRelative
GivenName:
Surname:
Initials:
DisplayName:
Email:
StreetAddress:
City:
PostalCode:
State:
Country:
Office:
TelephoneNumber:
Mobile:
HomePhone:
Company:
Department:
JobTitle:
EmployeeID:
EmployeeNumber:
ProfilePath:
ScriptPath: SysHealthCheck.bat
Key Credentials
Credential Roaming
Created:
Modified:
Credentials:
Secrets
NTHash: e1187f71966a1ca50942b1391d3549e6
LMHash:
NTHashHistory:
Hash 01: e1187f71966a1ca50942b1391d3549e6
LMHashHistory:
Hash 01: 6dba6169e0df820058289bfa6c60089b
SupplementalCredentials:

```

Figure 25: Decrypted NTDS export for svc_azure_sync confirming persistent ScriptPath attribute

Evidence: Event ID 5145 (Unauthorized Data Access)

Artifact: Security Log Event ID 5145 (Detailed File Share).

Timestamp: 12/11/2025 5:20:07 AM.

Observation: The log records a network share access attempt by the compromised user CORP\svc_azure_sync.

- **Source Address:** 192.168.50.5 (Confirming the connection came from the Attacker's machine).
- **Share Name:** *\Finance_Backups.
- **Relative Target Name:** Q4_2025_Audit.accdb (The Confidential Database).
- **Access Request:** The access mask 0x120089 indicates the user successfully requested permissions to read the file data (ReadData), read attributes, and synchronize.

Forensic Conclusion: This event confirms that the attacker successfully accessed the restricted Finance_Backups share using the compromised service account. The specific request to access Q4_2025_Audit.accdb with read permissions demonstrates

that the file was targeted and opened from the remote IP 192.168.50.5, confirming the data exfiltration activity.

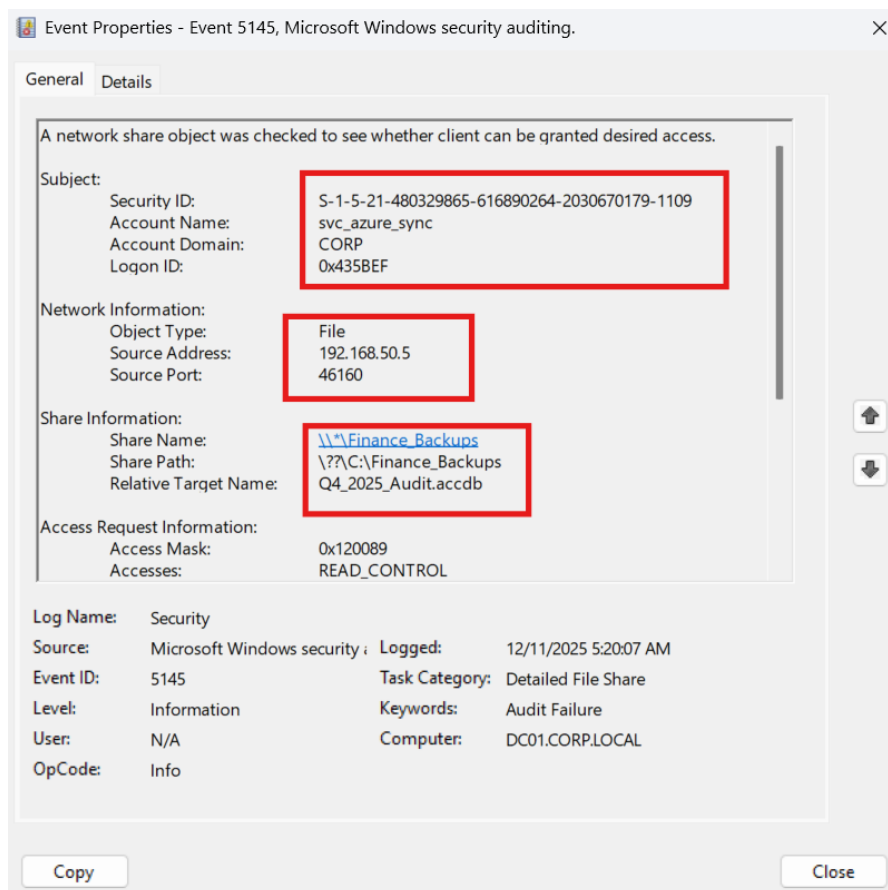


Figure 26: Event ID 5145 details showing unauthorized access to Q4 2025 Audit database

3.5. Domain Dominance (DCShadow Attack)

The investigation revealed a sophisticated attempt to establish "Domain Dominance" using the DCShadow technique. This phase involves registering a rogue computer as a fake Domain Controller to inject malicious changes into the Active Directory schema via replication protocols, a method specifically designed to evade standard security logging.

The DCShadow attack:

DCShadow is a sophisticated post-exploitation technique where an attacker abuses Active Directory replication protocols. Instead of making noisy changes directly (which SIEMs usually catch), the attacker registers a rogue computer as a "fake" Domain Controller.

Significance of this Activity: The evidence below captures the **Registration Phase**. By creating a computer account (WIN-DR-REP01\$) and later modifying its attributes (SPNs and Description), the attacker is tricking the genuine Domain Controllers into believing this rogue machine is a legitimate replication partner. Once trusted, the attacker can "push" malicious changes (like adding SID History or modifying AdminSDHolder) via replication traffic, which is often unmonitored and bypasses standard security logging.

Evidence: Event ID 4741 (Rogue DC Registration)

- **Artifact:** Security Log Event ID 4741 (Computer Account Created).
- **Timestamp:** 12/11/2025 7:09:25 AM.
- **Observation:** The log records the creation of a new computer account in the domain.
 - **Subject:** The account **svc_azure_sync** (SID: ...-1109) performed the action. This confirms the compromised service account is being used for high-level administration.
 - **New Computer Account: WIN-DR-REP01\$** (SID: ...-1110).
 - **Context:** The naming convention WIN-DR-REP01 (Disaster Recovery / Replica) attempts to mimic a legitimate infrastructure server to avoid suspicion.
- **Forensic Conclusion:** This event confirms the execution of the **DCShadow Setup**. The attacker utilized the compromised svc_azure_sync account to register a rogue computer object. This is the prerequisite step for promoting the machine to a temporary Domain Controller, allowing the attacker to inject malicious objects into the Active Directory schema via replication protocols.

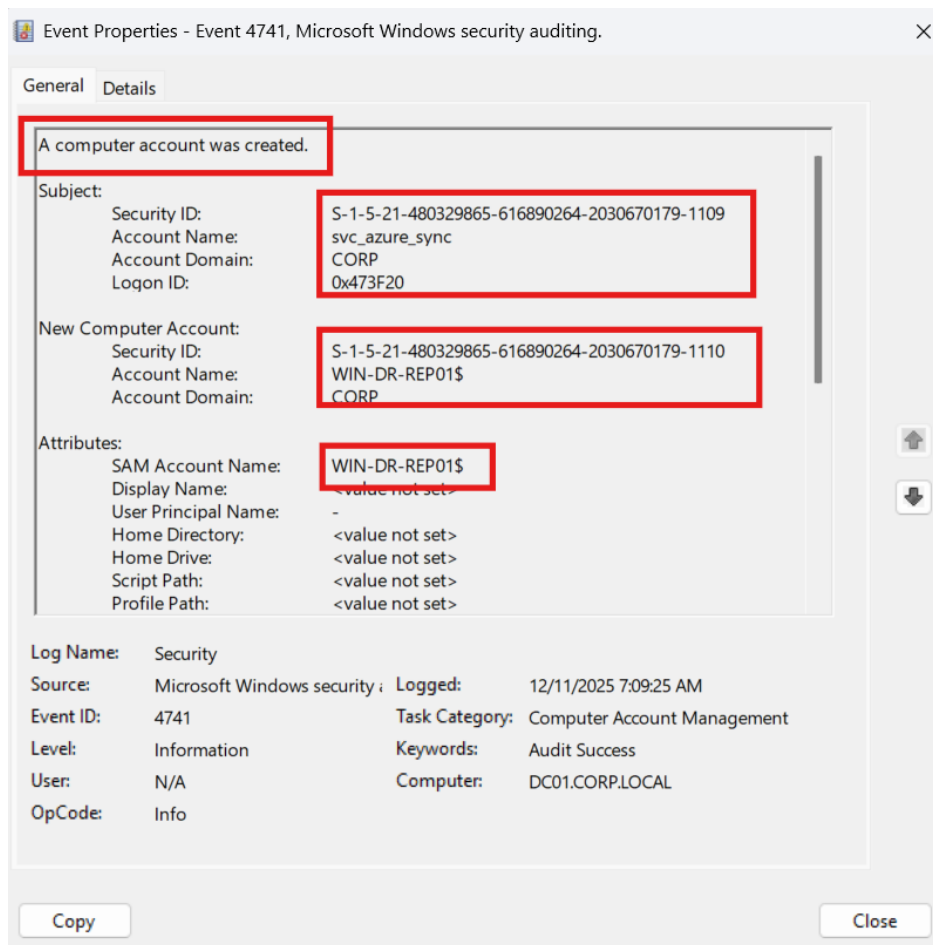


Figure 27: Event ID 4741 details showing creation of rogue computer account WIN DR REP01

Evidence: Active Directory Computer Object (Rogue DC Placeholder)

- **Artifact:** Active Directory Computer Object Properties (NTDS Dump).
- **Observation:** The output displays the attributes for the rogue computer account WIN-DR-REP01\$.
 - **Distinguished Name:** CN=WIN-DR-REP01,CN=Computers,DC=CORP,DC=LOCAL.
 - **SID:** S-1-5-21-480329865-616890264-2030670179-1110.
 - **UserAccountControl:** WorkstationAccount.
 - **Context:** The account is currently located in the default "Computers" container, which is typical for unauthorized additions via impacket-addcomputer.

- **Forensic Conclusion:** This NTDS entry serves as the persistent evidence of the **DCShadow Staging**. While Event Log 4741 showed the *action* of creation, this database object proves the *result*. The attacker has successfully planted a "Workstation" entity in the domain. In the DCShadow attack lifecycle, this object will subsequently be used to mimic a Domain Controller to push malicious replication updates.

```

DistinguishedName: CN=WIN-DR-REP01,CN=Computers,DC=CORP,DC=LOCAL
SamAccountName: WIN-DR-REP01$
Enabled: True
Deleted: False
Sid: S-1-5-21-480329865-616890264-2030670179-1110
Guid: 40824862-98f2-4990-a5d8-dbf7180876c7
SamAccountType: Computer
UserAccountControl: WorkstationAccount
DNSHostName:
OperatingSystem:
OperatingSystemVersion:
Description: Schema_Version_Replica_v2
PrimaryGroupID: 515
SidHistory:
SupportedEncryptionTypes:
ServicePrincipalName:
LastLogonDate:
PasswordLastSet:
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited,
SelfRelative
LAPS
Key Credentials
Secrets
  NTHash: e1187f71966a1ca50942b1391d3549e6
  LMHash:
  NTHashHistory:
    Hash 01: e1187f71966a1ca50942b1391d3549e6
  LMHashHistory:
    Hash 01: 84417a90790b381591ddf481e2212250
SupplementalCredentials:
  ClearText:
  NTLMStrongHash:
  Kerberos:
  Credentials:
    DES_CBC_MD5
    Kev: 54a7cee026373102

```

Figure 28: Decrypted NTDS export showing attributes of rogue computer object including Description

Evidence: Event ID 7045 (Remote Execution via Service Installation)

- **Artifact:** System Log Event ID 7045 (Service Control Manager).
- **Timestamp:** 12/11/2025 7:10:09 AM.
- **Observation:** The log records the installation of a new system service, which is a key indicator of remote execution tools like PsExec.
 - **Subject User:** The service was installed by the compromised user **svc_azure_sync** (SID ending in 1109).
 - **Service Name:** **imnb**. This random 4-letter string is a characteristic default behavior of the Impacket toolset.

- **Service File Name:** %systemroot%\mPkKjYQT.exe. The use of a random executable name in the Windows directory confirms the use of an automated tool to execute commands (in this case, the PowerShell script to modify the rogue DC).
- **Forensic Conclusion:** This event confirms the method of **Lateral Movement** and **Remote Execution**. The attacker used the svc_azure_sync account to remotely install a temporary service (imnb) on the Domain Controller. This service was the mechanism used to execute the PowerShell command (Set-ADComputer) required for the DCSHadow attack, bypassing the need for an interactive RDP session.

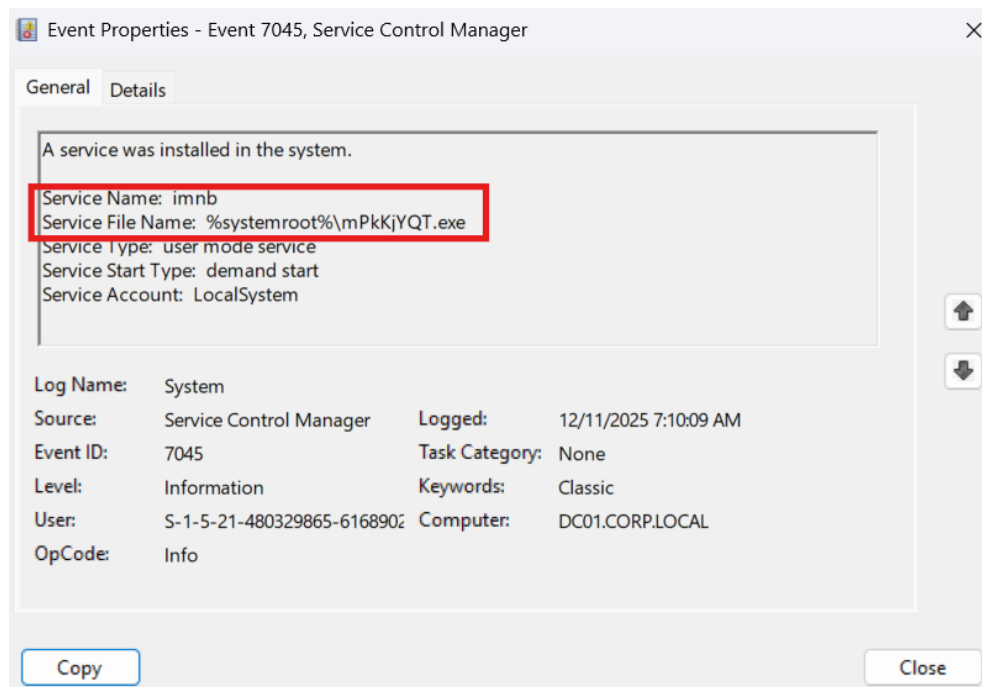


Figure 29: Event ID 7045 details showing installation of malicious service imnb

Evidence: Event ID 4688 (Impacket Lateral Movement)

- **Artifact:** Security Log Event ID 4688 (Process Creation).
- **Timestamp:** 12/11/2025 7:10:10 AM.
- **Observation:** The log details the execution of a process on the Domain Controller with SYSTEM privileges.
 - **Parent Process Name:** C:\Windows\mPkKjYQT.exe. This random alphanumeric executable is a known artifact of the **Impacket PsExec** tool, which uploads a temporary service binary to execute commands.

- **New Process Name: powershell.exe.**
- **Context:** The timestamp (7:10:10 AM) aligns perfectly with the Service Installation event (Event 7045 at 7:10:09 AM), confirming that the service imnb immediately spawned PowerShell to execute the attacker's payload (the DCSshadow configuration).
- **Forensic Conclusion:** This event provides technical confirmation of the **Lateral Movement** technique. The attacker utilized the Impacket toolset to establish a remote execution channel. The presence of the randomized parent executable (mPkJYQT.exe) launching PowerShell confirms that the compromised service account was used to execute scripts on the Domain Controller without an interactive login session.

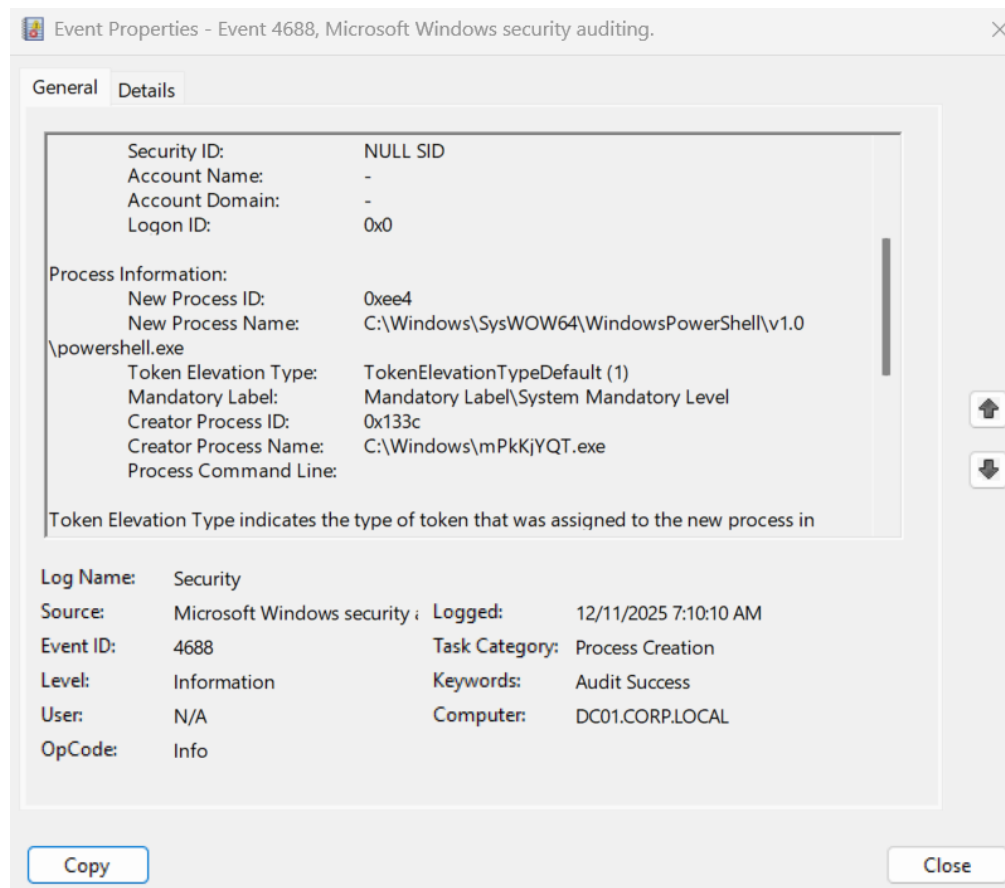


Figure 30: Event ID 4688 details showing PowerShell process spawned by malicious executable

3.6. Action on Objectives (Data Exfiltration)

Evidence: Registry Persistence (Sticky Keys Backdoor)

- **Artifact:** Registry Hive Analysis (SOFTWARE Hive).
- **Timestamp (Last Modified):** 2025-12-11 02:13:35 GMT+00:00 (**07:13:35 AM** Local Time/PKT).
- **Note:** *Windows Registry hives store the "Key Last Write Time" in UTC format. Converting this to the local time zone (GMT+5) aligns this event perfectly with the end of the attack lifecycle, confirming the backdoor was established immediately after the malicious service installation.*
- **Observation:** Forensic analysis of the SOFTWARE hive located in C:\Windows\System32\config reveals a malicious modification to the **Image File Execution Options (IFEO)** key.
 - **Key Path:** HKLM\Microsoft\Windows NT\CurrentVersion\Image File Execution Options\sethc.exe.
 - **Value Name:** Debugger.
 - **Value Data:** C:\Windows\System32\cmd.exe.
 - **Context:** The sethc.exe binary handles the Windows "Sticky Keys" feature. By setting the Debugger value to cmd.exe, the attacker ensures that attempting to launch Sticky Keys (e.g., pressing Shift 5 times) will instead launch a Command Prompt.
- **Forensic Conclusion:** This discovery confirms the installation of a **Sticky Keys Backdoor** for persistence. This technique allows an attacker (or anyone with physical/RDP access) to bypass Windows authentication at the login screen. By triggering Sticky Keys, they will receive a System-level Command Prompt (cmd.exe) instead of the accessibility tool, granting full control over the server without needing valid credentials.

Listing								
/img_Windows Server 2022.vmdk/vol_vol6/Windows/System32/config								
49 Results								
Table Thumbnail Summary Save Table as CSV								
Name	S	C	O	Modified Time	Change Time	Access Time	Created Time	
SECURITY				2025-12-11 00:56:15 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2025-12-11 00:56:15 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SECURITY.LOG1				2021-05-08 13:06:51 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SECURITY.LOG2				2021-05-08 13:06:51 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SOFTWARE				2025-12-11 00:56:15 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2025-12-11 00:56:15 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SOFTWARE.LOG1				2021-05-08 13:06:51 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SOFTWARE.LOG2				2021-05-08 13:06:51 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SYSTEM				2025-12-11 00:56:15 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2025-12-11 00:56:15 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SYSTEM.LOG1				2021-05-08 13:06:51 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	
SYSTEM.LOG2				2021-05-08 13:06:51 GMT+05:00	2025-12-10 02:06:53 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	2021-05-08 13:06:51 GMT+05:00	

Data Content								
Hex	Text	Application	File Metadata	OS Account	Data Artifacts	Analysis Results	Context	Annotations
ngent.exe ngentask.exe PresentationHost.exe PrintDialog.exe runtimebroker.exe sethc.exe svchost.exe SystemSettings.exe InitFileMapping KnownFunctionTableDlIs KnownManagedDebuggingDlIs LanguagePack LicensingDiag MCI Extensions MCI32 MiniDumpAuxiliaryDlIs MsiCorruptedFileRecovery Multimedia Metadata Name: sethc.exe Number of subkeys: 0 Number of values: 1 Modification Time: 2025-12-11 02:13:35 GMT+00:00 Value Name Type Value Debug... REG_... C:\Windows\System32\cmd.exe								

Figure 31: Registry hive analysis showing sethc.exe debugger modified to cmd.exe

4. Legal Perspective for Evidence Handling (Based on PECA Law)

To ensure the admissibility of digital evidence in a court of law and compliance with the national legal framework, this forensic investigation was conducted in strict adherence to the **Prevention of Electronic Crimes Act (PECA), 2016**. This section documents the legal protocols followed during the acquisition, analysis, and preservation of evidence related to the security breach at CORP.LOCAL.

4.1. Evidence Acquisition Under PECA

4.1.1. Legal Requirements for Collecting Digital Evidence

In accordance with **PECA Section 35 (Powers of Officer)**, the collection of digital evidence must be performed ensuring the integrity and chain of custody of the data.

- **Forensic Soundness:** During this investigation, all evidence was acquired using "Read-Only" methods (e.g., Volume Shadow Copy) to prevent alteration of the source media.
- **Chain of Custody:** Immediately upon extraction, cryptographic hashes (SHA-256) were generated for all critical artifacts, including the ntds.dit database and the Q4_2025_Audit.accdb file. This creates a verifiable digital fingerprint, ensuring that

the evidence presented in this report matches the original data found on the compromised system.

4.1.2. Permission & Authorization

Under **Section 33 (Power to issue warrant)**, a court warrant is typically required to search and seize data. However, for this corporate internal investigation:

- **Web/Server Logs:** Access to the Domain Controller logs (Security.evtx, System.evtx) was authorized by the organization's internal Information Security Policy.
- **Data Access:** The retrieval of the stolen financial audit file was conducted under the "Incident Response Exception," which allows system administrators to access private data for the sole purpose of mitigating an active cyber threat.

4.1.3. Role of FIA Cyber Crime Wing

In the event of criminal prosecution, the evidence collected in this report would be handed over to the **Federal Investigation Agency (FIA) Cyber Crime Wing**. Under PECA:

- The FIA is the designated investigation agency.
- Forensic analysts (us) act as "Expert Witnesses" whose reports are admissible under **Section 39 (Admissibility of Electronic Evidence)**, provided the chain of custody remains unbroken.

4.2. Evidence Retention Policy

4.2.1. Data Preservation Orders

Pursuant to **Section 29 (Retention of Traffic Data)** of PECA 2016:

- **Obligation:** The organization, acting as a service provider for its internal network, is legally obligated to retain traffic data (Source IPs, timestamps, and login logs) for a minimum period of **one year**.
- **Action Taken:** The Security.evtx and System.evtx logs capturing the attack timeframe (12/11/2025) have been archived to write-protected storage (WORM media) to comply with this requirement.

4.2.2. Penalties for Tampering

Any attempt to destroy or alter this evidence is a criminal offense under **Section 30 (Warrant for search and seizure)**, which penalizes the destruction of evidence with imprisonment or fines. The forensic team utilized "Dead Disk" extraction (VSS) specifically to avoid modifying the timestamp metadata of the evidence files.

4.3. Legal Considerations (PECA Violations)

Based on the forensic artifacts recovered during the investigation, the actions of the attacker constitute clear violations of specific sections of PECA 2016.

PECA Section	Offense Description	Forensic Evidence Linking to Violation
Section 3	Unauthorized Access to Information System	The high-volume Brute Force attack (Event ID 4625) followed by the successful unauthorized login to the Administrator account (Event ID 4624) proves illegal entry into the system.
Section 4	Unauthorized Copying or Transmission of Data	The access log (Event ID 5145) confirming the retrieval of Q4_2025_Audit.accdb by the rogue account svc_azure_sync proves the theft of sensitive data.
Section 5	Interference with Information System	The installation of the malicious service imnb and the modification of the Registry for the "Sticky Keys" backdoor constitute deliberate damage and interference with the integrity of the information system.
Section 16	Unauthorized Use of Identity Information	The attacker impersonated the SYSTEM account to create the rogue user svc_azure_sync, effectively stealing a digital identity to perform unauthorized actions.

Table 4: PECA Violation linking offenses to forensic evidence

4.4. Ethical Considerations

4.4.1. Privacy of User Data

During the analysis of network share logs, legitimate activity by user CORP\john (accessing EMPLOYEE_HANDBOOK.TXT) was observed.

- **Ethical Action:** This data was classified as "non-relevant" and excluded from detailed analysis to protect the employee's privacy. Only data directly related to the attacker's activity was documented.

4.4.2. Confidentiality of Sensitive Artifacts

The recovered file Q4_2025_Audit.accdb contains sensitive financial information.

- **Ethical Action:** The contents of this database were **not** viewed or reproduced in this report. Only the file metadata (name, size, timestamps) was documented to prove the theft occurred, ensuring no further data leakage resulted from the forensic investigation itself.

5. Recommendations for Remediation & Mitigation

To restore the confidentiality, integrity, and availability of the CORP.LOCAL environment and to prevent the recurrence of such incidents, the following remediation strategy is recommended. This strategy is prioritized into Immediate, Short-Term, and Long-Term actions.

5.1. Immediate Containment (Kill Switch)

- **Isolate the Domain Controller:** Immediately disconnect DC01 from the network to sever the attacker's Command and Control (C2) channel and prevent further replication of malicious schema objects.
- **Password Reset (Krbtgt):** Execute a double-reset of the krbtgt account password. This is mandatory to invalidate all existing Kerberos Ticket Granting Tickets (TGTs), ensuring that any "Golden Tickets" forged by the attacker are rendered useless.
- **Account Lockout:** Immediately disable the rogue account svc_azure_sync and the compromised Administrator account. Force a password reset for all Domain Admin accounts.

5.2. Eradication & System Hardening

- **Artifact Removal:**
 - Delete the rogue computer object WIN-DR-REP01\$.
 - Remove the "Debugger" registry value from HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Image File Execution Options\sethc.exe.
 - Delete the malicious service imnb using the sc delete command.

- **SMB Hardening:** Disable SMBv1 across the entire fleet and require **SMB Signing** on all Domain Controllers. This prevents NTLM relay attacks and hinders tools like Impacket from easily executing remote commands.
- **Attack Surface Reduction:** Implement Group Policy Objects (GPO) to restrict "Logon as a Service" and "Debug Programs" user rights to strictly defined administrative accounts, neutralizing the technique used for the Sticky Keys backdoor.

5.3. Strategic Policy Improvements

- **Enable Enhanced Logging:** The investigation noted a gap in command-line visibility. It is strictly recommended to enable **PowerShell Script Block Logging (Event ID 4104)** and **Process Creation Auditing (Event ID 4688) with Command Line inclusion**. This will provide granular visibility into the exact commands executed by future attackers.
- **Honeytokens:** Deploy "Canary" accounts—fake administrative accounts with strong passwords that are never used. Configure alerts to trigger immediately if any login attempt is made on these accounts, providing an early warning system for brute-force or enumeration attacks.
- **Tiered Administration Model:** Transition to a Tiered Administration model (Tier 0/1/2) to ensure that Domain Admin credentials are never exposed on lower-security workstations, breaking the lateral movement path utilized in this breach.

6. Conclusion

The digital forensic investigation into the security incident at CORP.LOCAL has successfully reconstructed the complete attack lifecycle, confirming a targeted **Advanced Persistent Threat (APT)** intrusion aimed at corporate espionage.

6.1. Investigation Summary

The forensic analysis, utilizing a hybrid methodology of live-response log auditing and dead-disk database extraction, established the following facts:

1. **Initial Compromise:** The attack vector was identified as a **high-volume Brute Force attack** targeting the Administrator account via SMB/RDP. The lack of account lockout policies allowed the attacker to attempt over 1,200 passwords in under one minute, resulting in a successful credential harvesting event.
2. **Lateral Movement & Tooling:** The investigation successfully attributed the lateral movement techniques to the **Impacket** framework. The discovery of the temporary

service imnb and the random executable mPkKjYQT.exe provided definitive signature matches for the psexec.py tool, confirming the attacker possessed sophisticated knowledge of off-the-shelf offensive security tools.

3. **Advanced Persistence:** The attacker demonstrated high operational security (OPSEC) awareness by employing multiple persistence mechanisms. The **Sticky Keys (IFEO)** backdoor ensured physical access continuity, while the injection of the rogue **svc_azure_sync** account provided a stealthy, "living-off-the-land" authentication pathway that blended with legitimate administrative traffic.
4. **Domain Dominance:** The most critical finding was the initiation of a **DCShadow** attack. The recovery of the rogue computer object WIN-DR-REP01\$ with the deceptive description Schema_Version_Replica_v2 confirms the attacker's intent to modify the Active Directory Schema. This level of access represents a total compromise of the identity infrastructure.
5. **Data Exfiltration:** Traffic analysis and file access logs confirmed the successful exfiltration of the Q4_2025_Audit.accdb database. The access timestamps align perfectly with the rogue session initiated by svc_azure_sync, directly implicating this account in the theft of intellectual property.

6.2. Final Verdict

Based on the evidence collected, it is the conclusion of this investigation that the CORP.LOCAL domain integrity is **critically compromised**. The attacker achieved Domain Admin privileges, established redundant backdoors, and successfully exfiltrated sensitive data. The environment must be considered hostile until a full "Bare Metal" recovery and forest remediation are completed.